



**Report on Management of Deloitte LLP's Description of its
Infrastructure Support Services System and the Suitability of Design
and Operating Effectiveness of its Controls Relevant to Security and
Availability**

SOC 2® Type 2 Report

October 1, 2024 to September 30, 2025

DELOITTE LLP
INFRASTRUCTURE SUPPORT SERVICES SYSTEM
SOC 2 TYPE 2

I.	Independent Service Auditor’s Report Provided by KPMG LLP	4
II.	Management of Deloitte LLP’s Assertion	9
III.	Management of Deloitte Technology Limited’s Assertion	11
IV.	Management of Deloitte LLP’s Description of its Infrastructure Support Services System.....	13
	System Overview and Services Provided	14
	Description Criteria That Are Not Relevant to the System.....	15
	Principal Service Commitments and System Requirements	16
	Components of the System	17
	Trust Services Criteria and Related Controls	21
	Complementary User Entity Controls.....	35
	Trust Services Criteria and Related Controls	36
V.	Trust Services Criteria, Deloitte LLP and Deloitte TECHNOLOGY Limited’s Controls, and KPMG LLP’s Test of Controls and Results of Tests.....	37
	KPMG LLP’s Test Procedures	38
	Security and availability Categories and Criteria and Related Controls.....	39
VI.	Other Information Provided by Management of Deloitte LLP.....	128
	Management Responses	129

I. INDEPENDENT SERVICE AUDITOR'S REPORT PROVIDED BY
KPMG LLP



KPMG LLP
1201 Demonbreun Street
Suite 1100
Nashville, TN 37203

Independent Service Auditors' Report

Management of Deloitte LLP:

Scope

We have examined management of Deloitte LLP's accompanying description of its system titled "Management of Deloitte LLP's Description of its Infrastructure Support Services System" throughout the period October 1, 2024 to September 30, 2025 (the Description), based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report*, in AICPA *Description Criteria* (the Description Criteria), and the suitability of the design and operating effectiveness of controls stated in the Description throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that Deloitte LLP's service commitments and system requirements were achieved based on the trust services criteria relevant to security and availability (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, in AICPA *Trust Services Criteria*.

Deloitte Technology Limited is a subservice organization that provides infrastructure support services to Deloitte LLP. The Description includes those elements of the infrastructure support services provided to Deloitte LLP and the controls designed and operated by Deloitte Technology Limited that are necessary for Deloitte LLP to achieve its service commitments and system requirements based on the applicable trust services criteria.

The information included in Section VI, "Other Information Provided by Management of Deloitte LLP", is presented by management of Deloitte LLP to provide additional information and is not a part of the Description. Information about Deloitte LLP's management responses to exceptions identified in the report has not been subjected to the procedures applied in the examination of the Description and of the suitability of the design and operating effectiveness of controls to achieve Deloitte LLP's service commitments and system requirements based on the applicable trust services criteria and, accordingly, we express no opinion on it.

The Description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Deloitte LLP and Deloitte Technology Limited, to achieve Deloitte LLP's service commitments and system requirements based on the applicable trust services criteria. The Description presents Deloitte LLP and Deloitte Technology Limited's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

Subservice Organization's Responsibilities

Deloitte Technology Limited has provided the accompanying assertion titled "Management of Deloitte Technology Limited's Assertion" about the Description and the controls stated therein. Deloitte Technology Limited is responsible for preparing the portion of the Description related to infrastructure support services provided to Deloitte LLP and Deloitte Technology Limited assertions, including the completeness, accuracy, and method of presentation of the Description and Assertion; providing the services covered by the Description; and implementing and documenting controls designed by Deloitte Technology Limited, which enable Deloitte LLP to achieve its service commitments and system requirements.



Service Organization's Responsibilities

Deloitte LLP is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Deloitte LLP's service commitments and system requirements were achieved. Management of Deloitte LLP has provided the accompanying assertion titled "Management of Deloitte LLP's Assertion" (the Assertion) about the Description and the suitability of design and operating effectiveness of controls stated therein. Deloitte LLP is also responsible for preparing the Description and Assertion, including the completeness, accuracy, and method of presentation of the Description and Assertion; providing the services covered by the Description; selecting the applicable trust services criteria and stating the related controls in the Description; and identifying the risks that threaten the achievement of Deloitte LLP's service commitments and system requirements.

Service Auditors' Responsibilities

Our responsibility is to express an opinion on the Description and on the suitability of the design and operating effectiveness of the controls stated in the Description based on our examination.

Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, the Description is presented in accordance with the Description Criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- obtaining an understanding of the system and the service organization's service commitments and system requirements
- assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization would achieve its service commitments and system requirements based on the applicable trust services criteria if those controls operated effectively
- testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.



Inherent Limitations

The Description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that each individual report user may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls tested and the nature, timing, and results of those tests are listed in Section V.

Opinion

In our opinion, in all material respects,

- the Description presents Deloitte LLP's Infrastructure Support Services system that was designed and implemented throughout the period October 1, 2024 to September 30, 2025 in accordance with the Description Criteria
- the controls stated in the Description, including the controls designed and operated by Deloitte Technology Limited, were suitably designed throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that Deloitte LLP's service commitments and system requirements would be achieved based on the applicable trust services criteria if the controls operated effectively throughout that period, and user entities applied the complementary controls assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls throughout the period October 1, 2024 to September 30, 2025.
- the controls stated in the Description, including the controls designed and operated by Deloitte Technology Limited, operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that Deloitte LLP's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary user entity controls, assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls, operated effectively throughout the period October 1, 2024 to September 30, 2025.

Restricted Use

This report, including the description of tests of controls and results thereof in Section V, is intended solely for the information and use of Deloitte LLP, user entities of Deloitte LLP's Infrastructure Support Services system during some or all of the period October 1, 2024 to September 30, 2025, business partners of Deloitte LLP that were subject to risks arising from interactions with Deloitte LLP's Infrastructure Support Services system, and practitioners providing services to such user entities and business partners, who have sufficient knowledge and understanding of the following:

- the nature of the service provided by the service organization
- how the service organization's system interacts with user entities, business partners, subservice organizations, and other parties
- internal control and its limitations



- complementary user entity controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- user entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- the applicable trust services criteria
- the risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be and should not be used by anyone other than these specified parties.

KPMG LLP

Nashville, Tennessee
November 19, 2025

II. MANAGEMENT OF DELOITTE LLP'S ASSERTION



Management of Deloitte LLP's Assertion

We have prepared the accompanying description of Deloitte LLP's system titled "Management of Deloitte LLP's Description of Its Infrastructure Support Services System" throughout the period October 1, 2024 to September 30, 2025 (the Description), based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report*, in AICPA *Description Criteria* (the Description Criteria). The Description is intended to provide report users with information about the Infrastructure Support Services system that may be useful when assessing the risks arising from interactions with Deloitte LLP's system, particularly information about system controls that Deloitte LLP has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and availability (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*, in AICPA *Trust Services Criteria*.

Deloitte LLP's Description includes a description of Deloitte Technology Limited's infrastructure support services used by Deloitte LLP to provide Infrastructure Support Services for user entities and business partners, including the controls of Deloitte LLP and the controls designed and operated by Deloitte Technology Limited that are necessary for Deloitte LLP to achieve Deloitte LLP's service commitments and system requirements based on the applicable trust services criteria. Deloitte Technology Limited's assertion is presented in Section III.

The Description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at Deloitte LLP and Deloitte Technology Limited, to achieve Deloitte LLP's service commitments and system requirements based on the applicable trust services criteria. The Description presents Deloitte LLP and Deloitte Technology Limited's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls.

We confirm, to the best of our knowledge and belief, that:

- a. The Description presents Deloitte LLP's Infrastructure Support Services system that was designed and implemented throughout the period October 1, 2024 to September 30, 2025, in accordance with the Description Criteria.
- b. The controls stated in the Description, including the controls designed and operated by Deloitte Technology Limited, were suitably designed throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that Deloitte LLP's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and user entities applied the complementary controls assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls throughout the period October 1, 2024 to September 30, 2025.
- c. The controls stated in the Description, including the controls designed and operated by Deloitte Technology Limited, operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that Deloitte LLP's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary user entity controls, assumed in the design of Deloitte LLP and Deloitte Technology Limited's controls, operated effectively throughout the period October 1, 2024 to September 30, 2025.

III. MANAGEMENT OF DELOITTE TECHNOLOGY LIMITED'S ASSERTION



Management of Deloitte Technology Limited's Assertion

Deloitte Technology Limited provides infrastructure support services to Deloitte LLP. The services provided by Deloitte Technology Limited are part of Deloitte LLP's Infrastructure Support Services system. We have prepared the portion of the accompanying description of Deloitte LLP's Infrastructure services titled "Management of Deloitte LLP's Description of its Infrastructure Support Services System," throughout the period October 1, 2024 to September 30, 2025 (the Description) disclosing Deloitte Technology Limited's infrastructure support services provided to Deloitte LLP based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) (description criteria). The Description is intended to provide report users with information about Deloitte LLP's Infrastructure Support Services system that may be useful when assessing the risks arising from interactions with Deloitte LLP's system, particularly information about system controls that Deloitte LLP has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and availability set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

We confirm, to the best of our knowledge and belief, that:

- a. The Description presents Deloitte Technology Limited's infrastructure support services made available to Deloitte LLP throughout the period October 1, 2024 to September 30, 2025, in accordance with the description criteria.
- b. Deloitte Technology Limited's controls stated in the Description, which were designed by Deloitte Technology Limited, were suitably designed throughout the period October 1, 2024 to September 30, 2025 based on the applicable trust services criteria.
- c. Deloitte Technology Limited's controls stated in the Description operated effectively throughout the period October 1, 2024 to September 30, 2025 based on the applicable trust services criteria.

IV. MANAGEMENT OF DELOITTE LLP'S DESCRIPTION OF ITS INFRASTRUCTURE SUPPORT SERVICES SYSTEM

SYSTEM OVERVIEW AND SERVICES PROVIDED

Company Overview

Services are delivered to clients through certain of the subsidiaries of Deloitte LLP (“DLLP”), including Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Financial Advisory Services LLP, Deloitte Transactions and Business Analytics LLP, and Deloitte Tax LLP (collectively, the “Deloitte U.S. Firms”). DLLP, through its subsidiary, Deloitte Services LP, provides various infrastructure, technology, and hosting services through the Deloitte Technology US (DT-US) team to the Deloitte U.S. Firms, with the support of Deloitte Technology Limited (DTL), a UK private company limited by guarantee, through its Global Deloitte Technology (DT) teams.

DT-US provides Infrastructure Support Services to the Deloitte U.S. Firms in its on-premises data center located in Hermitage, Tennessee. The Hermitage Data Center hosts production network infrastructure and production servers, and tools to manage the infrastructure and production network infrastructure that supports these critical shared services.

Subservice Organizations

DLLP outsources certain infrastructure support services to DTL. Controls executed by DTL on behalf of DLLP related to infrastructure are within the scope of this report and are provided through its Global Deloitte Technology (DT) teams.

Scope of this Report

The scope of this report includes Infrastructure Support Services for client-facing applications that are hosted in DLLP’s data center located in Hermitage, Tennessee. The infrastructure environment does not include servers hosting applications for DLLP’s internal or back-office use or laptops outside of the Windows operating system environment.

The scope of this report also includes the support services provided by DLLP’s India based subsidiaries (“U.S. India” or “USI”) in Hyderabad, Bengaluru, Mumbai Gurgaon, Pune, Chennai, and Kolkata and DLLP’s Mexico based subsidiaries (“U.S. Mexico” or “USM”) which have offices in Queretaro. While these locations do not house servers, they do house network equipment and support professionals.

DLLP utilizes DTL for certain infrastructure support services. The scope of this report excludes the following:

- Applications or databases
- Systems or services used by DT-US for back-office purposes

DESCRIPTION CRITERIA THAT ARE NOT RELEVANT TO THE SYSTEM

The following description criteria are not relevant to the system:

Description Criteria	Rationale
Description Criteria 4: For identified system incidents that (a) were the result of controls that were not suitably designed or operating effectively or (b) otherwise resulted in a significant failure in the achievement of one or more of those service commitments and system requirements, as of the date of the description (for a type 1) or during the period of time covered by the description (for a type 2), as applicable, the following information: • Nature of each incident • Timing surrounding the incident • Extent (or effect) of the incident and its disposition	There were no identified system incidents that were the result of controls that were not suitably designed or otherwise resulted in a significant failure in the achievement of one or more of those service commitments and requirements.
Description Criteria 9: In a description that covers a period of time (type 2 examination), the relevant details of significant changes to the service organization's system and controls during that period that are relevant to the service organization's service commitments and system requirements.	There were no significant changes to the service organization's system and controls during the period that are relevant to the service organization's service commitments and system requirements.

PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS

DLLP makes service commitments to its external users and has established system requirements as part of its Infrastructure Support Services. Some of these commitments are principal to the performance of the services provided in the scope of this report and relate to the applicable trust services criteria. DLLP is responsible for its service commitments and system requirements, and for the design, implementation, and operating effectiveness of controls within the system to provide reasonable assurance that DLLP's service commitments and system requirements are achieved.

DLLP communicates its service commitments to external users through documentation of the description of its system and service offerings on DLLP's intranet site, the Information Security Statement, Statements of Work (SOWs), and Service Level Agreements (SLAs).

The principal service commitments related to security and availability include, but are not limited to:

- Implementing logical access controls for the DLLP network and servers
- Managing network connectivity
- Providing security controls through configuration and management of domain controllers, firewalls, and load balancers
- Providing operating systems support (patching, anti-virus and anti-malware protection, and vulnerability management)
- Providing support to identify, analyze, and remediate security and availability alerts
- Providing 24/7 system availability monitoring

DLLP also has operational requirements that support the achievement of other service commitments and system requirements as well as applicable laws and regulations. These requirements are communicated to internal users through documented standards, policies, procedures, and system design documentation.

COMPONENTS OF THE SYSTEM

The components of DLLP's system used to provide services within the scope of this report are as follows and are described in detail below:

- Infrastructure – The physical structures, IT, and other hardware (for example, facilities, laptops, equipment, mobile devices, and telecommunications networks)
- Software – IT system software that supports Infrastructure Support Services programs (operating systems, middleware, and utilities)
- People – The professionals involved in the governance, operation, and use of a system (developers, operators, entity users, vendor personnel, and managers)
- Procedures – The automated and manual procedures used in operation of the system
- Data – Transaction streams, files, tables, and output used or processed by the system

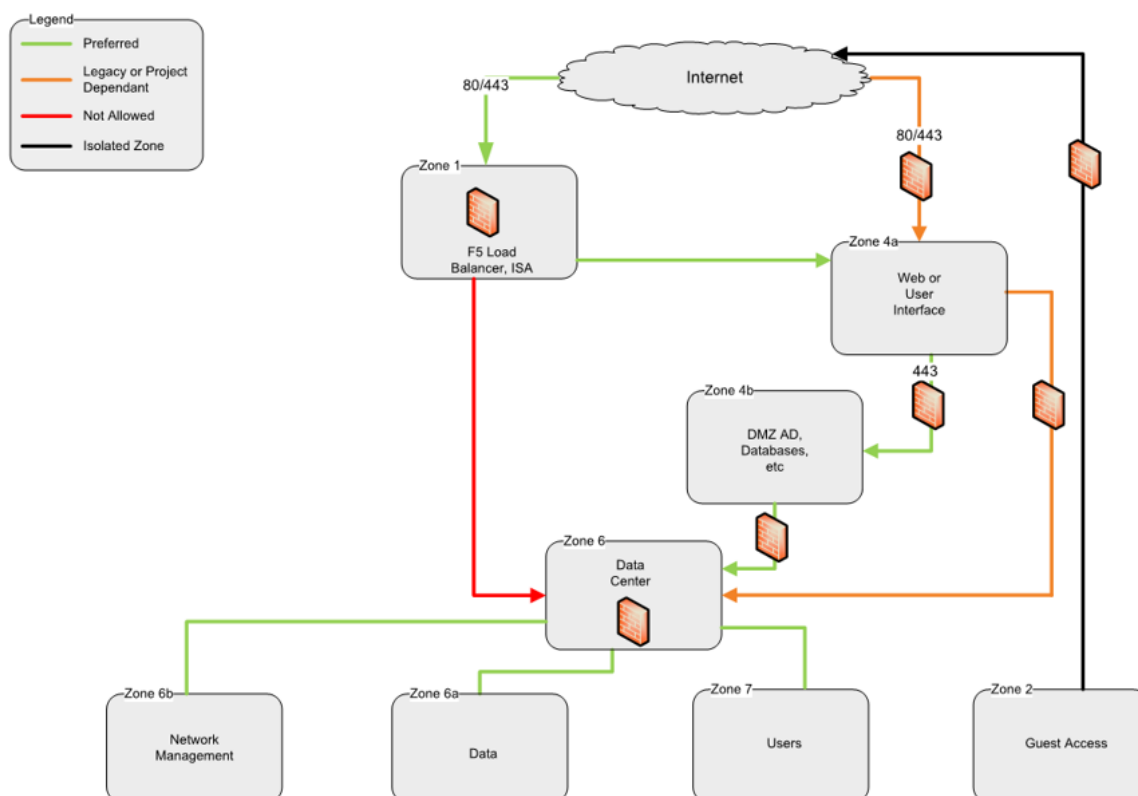
Infrastructure

The following processes are used to support the infrastructure at DLLP:

- Data centers
- Business continuity
- Disaster recovery (DR)
- Security monitoring, scanning and support systems
- Core infrastructure monitoring tools and supporting systems
- Service Desk
- Service operation center systems
- Access management and directory services
- Data backup services
- Remote access systems and services
- Networking infrastructure and tools
- Anti-virus and anti-malware management
- Vulnerability and patch management services
- Security incident management
- Firewall management

The diagram below illustrates the Infrastructure Support Services architecture:

Zone Flow – Basic Rules for Zone Flow



Software

DLLP's tools/systems listed under the heading "Infrastructure" support the Windows and Linux operating system software.

The professionals of DLLP and the Deloitte U.S. Firms access the tools/systems through their organization-supplied laptops either by connecting to the network in offices or through a VPN gateway using Advanced Encryption Standard (AES) 256-bit.

Modern Access Control (MAC) is the name for DLLP's Identity Governance and Administration platform based on SailPoint's IdentityIQ software. MAC empowers business users with automated access requests and provides access right owner the ability to review access membership for appropriateness on a quarterly.

Secret Server is a centrally managed privileged account management solution that protects DLLP's privileged accounts. Secret Server manages privileged accounts by requiring standard users to pass MFA to gain access to Secret Server. Secret Server only allows access to privileged accounts each user has access. If a privileged account is checked out (used) then Secret Server will manage the privileged account and rotate the password upon check-in.

Configuration Management Database (CMDB) is an inventory tool for assets. CMDB pulls data from assets utilizing periodic probes every two to six hours depending on the environment and is integrated with event feeds to update asset information in real time.

Compass is a reporting/repository tool that pulls data from Omni for reporting purposes. It is configured to pull data directly from Omni and store it in the Compass database. Then, application programming interfaces (APIs) are used to pull the data from the Compass database and display the data in the Compass dashboard as a report.

Splunk is a security monitoring and data analysis tool that provides comprehensive security monitoring, threat detection, and incident response capabilities. Splunk collects logs, which contain events, from various technologies that represent the IT environment. Logs are collected from Splunk Forwarding agents and/or collection servers around the DLLP network. Splunk then uses threat detection rules to monitor, detect, and alert on unusual and potentially malicious behavior. Once a Splunk alert is triggered, it is automatically fed into a ServiceNow ticket.

SolarWinds is a network performance monitoring tool that provides comprehensive monitoring of network devices, including routers, switches, and firewalls. It provides monitoring capabilities for health and performance metrics.

Dynatrace is a comprehensive software intelligence platform that provides advanced availability monitoring and performance management for the infrastructure, including servers and VMs. Dynatrace leverages artificial intelligence (AI) to provide performance metrics and perform automatic root cause analysis to identify the underlying causes of any performance issues.

People

Services addressed in this report: are provided by Talent (which consists of all aspects of Human Resources [HR], including recruiting, performance management, and resource scheduling), Finance and Administration, Office of Security, Service Reliability Center (SRC), DT teams (Vulnerability Management, Firewall Managed Services, and Active Directory® (AD) Administration) and DT-US teams (DT-US Cyber Security, Patch Management, Network Operations, Access Services, Cyber Defense, Security Standards and Architecture, Security Operations Center, and Cyber Security Risk and Compliance (CSRC)).

Procedures

DLLP's management has developed information technology (IT) policies and procedures for various operations, which are communicated to respective stakeholders. The policies and procedures are reviewed periodically and any necessary changes to these policies and procedures are authorized by senior management.

These policies and procedures cover the following key lifecycle areas:

- Assessment of the business impact of proposed security approaches
- Selection, design, documentation, and implementation of security controls
- Authorization of, changes to, and termination of information system access
- Monitoring of security controls and events
- Management of access control and roles
- Maintenance and support of the security system and necessary backups
- Security incident response
- Maintenance of restricted access to system configurations, super user functionality, master passwords, powerful utilities, and security devices (e.g., firewalls)

These policies and procedures are located on DLLP's intranet.

Data

Data is managed, processed, and stored in accordance with relevant data protection policies and procedures, with specific data-processing requirements formally established in external third-party contracts or in accordance with applicable laws or regulations. This data is managed and stored in a range of database technologies, including SQL Server and Oracle®.

Data is managed, processed, and stored, and includes the following:

- System, audit, and event logs
- Access event records
- System configuration and hardening information
- Backup data

TRUST SERVICES CRITERIA AND RELATED CONTROLS

Relevant Aspects of the Control Environment, Risk Assessment, Information and Communication, and Monitoring

Control Environment

Board of Directors

The control environment of DLLP is influenced by the Board of Directors (“Board”) and its seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, working with management and the full Board. Board committees are required to formally report to the Board on their activities, including issues of internal control within DLLP.

Board member expertise and experience include an understanding of the organization's business operations, strategic initiatives, and major transactions, and may present alternate views.

Integrity and Ethical Values

The Board of DLLP has adopted a Code of Ethics and Professional Conduct (“Code”) that serves as a guide for actions and behaviors to be followed by its professionals.

The Code defines the expectations for all DLLP professionals, including their obligation to report any potential violations, and documents a sanctions policy for those who violate the Code. All professionals are required to know, understand and comply with the Code, both in letter and in spirit.

Professionals receive periodic reminders to comply with the Code and must complete a review of the Code as a part of their annual independence representation.

Ethics and Compliance Department – Board of Directors and Senior Leadership

The Chief Ethics and Compliance Officer designs and provides reports to the Board on compliance matters and organizes annual meetings with the senior leadership team for their compliance review.

Ethics and Compliance Hotline

A confidential and anonymous Ethics and Compliance Hotline is available for DLLP professionals to report issues. The hotline is accessible 24x7 by phone, online, or via mobile device. The individual may also send a letter reporting the concern to Chief Ethics and Compliance Officer.

Professionals are instructed that it is their duty to promptly report any concerns of suspected or known violations of the Code or other policies or guidelines of DLLP. The procedures to be followed for making such a report are outlined on the Ethics and Compliance intranet page. DLLP professionals are also encouraged to communicate the issue to their manager, their manager’s manager, their HR contact, or the Office of Compliance or Integrity Helpline.

Internal and External Reporting Objectives

DLLP communicates its objectives and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through channels such as a post on DLLP’s intranet site or email.

Training

DLLP provides compliance and role-based training opportunities to all professionals. Independence, ethics, and confidentiality training is required of all DLLP professionals. The independence training includes an anti-corruption section that focuses on DLLP's anti-corruption policies and highlights policies that reinforce the need for DLLP professionals to work with integrity and comply with the anti-corruption laws of the countries in which DLLP operates. Active DLLP professionals are required to complete these training courses and compliance with all mandatory courses is tracked on an ongoing basis.

Accountability

DLLP professionals are accountable for understanding and adhering to the guidance in the DLLP Cyber Security policy, any applicable supporting standards, and all Administrative Policy Releases (APRs). Any individual not employed by DLLP (e.g., visitors accessing the guest network, contractors or vendors accessing the DLLP VPN), but allowed to access, manage, or process information assets of DLLP, is also accountable for understanding and adhering to the guidance in the Cyber Security policy and standards. Contractors are required to sign an agreement that establishes standards of conduct regarding security, confidentiality, privacy, personally identifiable information (PII), and the disclosure of such information.

Commitment to Competence

The hiring managers of DLLP define appropriate job requirements prior to recruiting, interviewing, and hiring for a position of employment. Job requirements include the primary responsibilities and tasks involved in the job, the background needed to perform the job, and personal characteristics required. Minimum education and prior work experience are also documented as part of the hiring requirements. These areas are documented for professionals responsible for designing, developing, implementing, operating, maintaining, and monitoring the security and availability of the system. Once the requirements have been determined, managers create a job description, which is used to identify potential candidates. When viable candidates are identified, the interview process begins.

DLLP professionals have defined and documented information security roles and responsibilities, which are communicated to such professionals upon hire or role change. A periodic performance management process is executed for DLLP professionals with a discussion about strengths and any identified challenges.

Internal Audit

DLLP has an Internal Audit (IA) function that reports directly to the Audit Committee (AC) of the Board. IA has a charter that is reviewed by the AC and senior leadership. Responsibilities of IA include performing audits and reporting findings and recommendations to the AC and senior leadership. Internal audits are performed based on the annual risk-based internal audit plan. Identified internal control deficiencies from IT assessments are communicated to management and tracked to appropriate resolution.

System Audits

Internal security control reviews are performed periodically based on the business impact on the systems. DLLP's IA team performs audits on various aspects of DLLP's systems, processes, and policies.

DLLP's Information Security Management System (ISMS) is reviewed by an independent firm for ISO 27001, 27017, and 22301 certifications.

Organizational Structure

DLLP management reports to DLLP's senior management professionals. The business purpose of the legal entities is evident and reasonable. Each of the legal entities has assigned responsibility, which is documented on DLLP's intranet site. This organizational structure helps control the activities and services available to the external users.

DT-US Cyber Security

DLLP maintains the DT-US Cyber Security department to oversee its cyber security program. The DT-US Cyber Security department is headed by DLLP's Chief Information Security Officer (CISO), who reports to DLLP's Chief Information Officer (CIO). The CISO is responsible for the design, development, implementation, operation, maintenance, monitoring, and approval of DLLP's system controls and other risk mitigation strategies for the system. The DT-US Cyber Security Strategy leader, Security Operations leader, Operations Engineering leader, and Risk and Compliance leader report to the CISO. The organizational chart is reviewed by DT-US Business Operations on an annual basis.

The DT-US Cyber Security department is divided into the following teams:

- Cyber Risk and Compliance
- Cyber Strategic Initiatives
- Cyber Security Operations
- Business Information Security Officers

DT-US Technology and Infrastructure

DLLP maintains the DT-US Technology and Infrastructure (T&I) department to oversee its infrastructure and technology operations. The DT-US T&I department is led by DLLP's Chief Technology Officer (CTO), who reports to DLLP's CIO. The T&I organization is responsible for availability, which includes the design, development, implementation, operation, maintenance, monitoring, and approval of DLLP's system controls and other risk mitigation strategies for the system. The organizational charts are reviewed by DT-US Business Operations on an annual basis.

Members of these DT-US teams hold various industry security and audit-based certifications (e.g., CISSP, CISM, CISA, ISSM, CRISC, CEH, and OSCP). The performance of professionals responsible for security and availability is reviewed on an annual basis by the individual's coach.

Human Resources Security

Upon hire, professionals must agree to comply with DLLP's policies, including those relating to information security, confidentiality and privacy. In addition, DLLP professionals are required to complete security awareness training during the new hire on-boarding process.

DLLP has an Acceptable Use Policy that sets out rules defining the way in which professionals are expected to properly use technology within the organization.

DLLP requires professionals to acknowledge the Acceptable Use Policy prior to gaining access to organizational information and information technology assets and annually thereafter.

Background Checks for U.S. Professionals

Background investigations are conducted for partners, principals, and other professionals at the time that they join DLLP. Potential issues that are identified in the background investigation are reviewed on an individual case-by-case basis considering guidance from the Equal Employment Opportunity Commission and applicable federal, state, and local law.

Background investigations of professionals in the U.S. include the following, at a minimum:

- SSN verification
- Felony and misdemeanor conviction searches:
 - Federal courts
 - County courts
 - State repositories, where the state has made one available and it is reasonably accessible
- A national criminal record database search, including the state sex offender registries
- Education confirmation: Education beyond high school confirmed
- Employment confirmation: Professional employment in the last five years is confirmed
- Searches of various government and criminal sanctions lists, such as SEC, OFAC, OIG/GSA, FDA, FBI Most Wanted, EU Terrorist Watch List, and Interpol Watch List
- Professional licenses: Confirm relevant professional licenses

Background Checks for Professionals in DLLP's Subsidiaries Located in India

Background investigations of professionals in DLLP's subsidiaries in USI include the following, at a minimum:

- Identity verification, where possible
- Criminal checks: Check all relevant court records for a five-year period
- Education confirmation: All university-level education is confirmed
- Employment confirmation: All professional employment in the last five years is confirmed
- Searches of various government and criminal sanctions lists, including India-specific and global databases
- Professional licenses: Confirm relevant professional licenses

Background Checks for Professionals in DLLP's Subsidiaries Located in Mexico

Background investigations of professionals in DLLP's subsidiaries in USM include the following, at a minimum:

- Identity verification
- Criminal checks: Check all relevant court records for a five-year period
- Education: Highest academic level is confirmed
- Employment confirmation: All professional employment in the last five years is confirmed
- Searches of various government and criminal sanctions lists, including Mexico-specific and global databases
- Professional licenses: Confirm relevant professional licenses
- Residence: Current address is verified

Security Awareness and Training

DLLP has implemented training and awareness programs for its professionals related to information security, confidentiality, and privacy policies and practices. DLLP professionals are required to complete information security, confidentiality, and privacy trainings during the new hire on-boarding process, as well as an annual update course thereafter. All professionals who have access to DLLP's intranet are presented with a policy awareness statement (which includes confidentiality, information security, and privacy policy requirements) at least once each year, which they are required to acknowledge. In addition, DLLP conducts an internal simulated phishing campaign to raise awareness and reduce risk amount professionals.

DLLP has a dedicated Security Awareness Committee. The committee is responsible for generating ideas to raise awareness of risks and to enhance the overall security culture through policy development and training. The committee meets regularly to discuss new and recurring security, confidentiality, and privacy issues, devise strategies and implementation plans, and to provide progress reports on existing projects. The committee is comprised of leadership and representatives from Cyber Security, Confidentiality & Privacy, Office of the CISO, Quality Risk Management, Talent, Office of General Counsel, and Deloitte Technology Limited's Global Information Security Office.

Acceptable Use

DLLP professionals are required to sign an Acceptable Use policy upon hire and acknowledge the security policies at least once per year.

Risk Assessment

DLLP reviews risk, as described below, to provide DLLP with consistent enterprise-wide risk management processes and create an enterprise view and understanding of risk. A formal risk governance program has been implemented and includes a risk governance plan, risk policy and procedures, business assets to be evaluated, threat types, risk training, risk evaluation criteria, and an annual risk assessment.

DLLP's IA, DT-US CSRC, and the DT-US T&I teams assess, test, and monitor in-scope systems and devices for compliance with relevant policies and standards. The Risk Committee meets periodically to discuss developments in technology and the impact of applicable laws or regulations on DLLP's availability and related security policies. A comprehensive risk assessment, including a technical risk assessment, is performed annually or when there are significant changes to the DLLP environment. An inventory of known risks and risk attributes is maintained, and a risk treatment plan is developed that serves as the basis for risk treatment decisions. A site-level threat assessment is conducted each fiscal year of the actual threat environment to identify environmental or physical threat changes. Relevant information resulting from IT assessments conducted by external parties is communicated to leadership as needed.

Fraud Risk Assessment

The Internal Controls Group (ICG) facilitates an annual fraud risk assessment that is completed with the Board, IA, and various business process owners to provide an understanding of potential fraud scenarios that may represent a risk to DLLP. The fraud risk assessment addresses risks related to professionals, processes, controls, systems, regulatory, industry, and usage of third parties/outside service providers, as well as other areas as applicable.

DT-US Cyber Security – Risk and Compliance

DT-US CSRC performs periodic risk assessments of IT. These assessments are reviewed by senior management within CSRC for appropriate action.

DT-US Cyber Security – Cyber Defense

Cyber Defense performs periodic technical vulnerability assessments and penetration tests to identify vulnerabilities and potential risks. These are reviewed by senior management within Cyber Defense and the respective Program Manager to determine appropriate action.

DT-US Cyber Security – Compliance Verification Program

The Compliance Verification Program (CVP) is designed to verify compliance against the controls identified in various risk and compliance programs, such as DT-US Risk Assessments, Internal Audits, External Audits, and Vulnerability Assessments. The following Risk Management domains are addressed by CVP:

- Access Control
- Asset Management
- Business Continuity Management
- Communications and Operations Management
- Compliance
- Human Resources Security
- Cyber Security Incident Management
- Information Systems Acquisition, Development, and Maintenance
- Physical and Environmental Security
- Risk Management
- Privacy Management

Independent Risk Assessment

On an annual basis, an independent team completes an assessment of the following security domains:

- Risk Management
- Information Security
- Asset Management
- Security Awareness and Training
- Physical, Environmental, and Infrastructure Security
- Access Management
- Secure Software Development Life Cycle (SSDLC)
- Business Continuity Management

Vendor/Third-party Risk Management Process

DLLP has established and assigned responsibility and accountability for the management of vendor/third-party risks. Vendor/third-party compliance requirements, service levels, and privacy and confidentiality requirements are written into the contract with the respective vendor as necessary based on the service provided. Additionally, standard contract templates are used for third-party vendors and deviations from those are reviewed and approved by key stakeholders. Executed contracts are retained with DLLP.

Vendors/third parties are subjected to an initial risk evaluation before the establishment of a relationship. They are then monitored on an ongoing basis based on the level of risk associated with the vendor/third party.

The Vendor Assessment process is designed to reduce vendor-related risks by:

- Building a repository of acceptable vendors
- Assessing the security posture of such vendors
- Tracking remediation of identified issues
- Reviewing and assisting with vendor contracts with respect to obligations relating to DLLP's information security program

DLLP's DT-US CSRC program is responsible for reviewing their vendors' compliance with a standard set of security requirements, based upon the type and volume of data the vendor will access, as well as the risk posed to DT-US and our clients. As part of this process, internal projects, as well as client-facing engagements, which require the services of a third-party vendor, must be added to the Third-Party Risk Management (TPRM) gateway by the DT-US representative seeking the vendor relationship. The DT-US Cyber Risk review is focused on third parties who will access, be provided with, store, or process DLLP and/or DLLP's client's data. Third parties rated as critical, high or medium risk must complete an online security questionnaire within DLLP's vendor risk assessment system. Third parties rated as critical risk undergo an additional in-person or virtual onsite assessment.

DLLP completes a review of its third-party service provider organizations' SOC 1 and SOC 2 reports, as applicable. The review includes the opinion, any exceptions, Complementary User Entity Controls (CUECs), and Complementary Subservice Organization Controls (CSOCs), and is completed to ensure relevance to the in-scope environment.

Information and Communication

Internal Communication

DLLP communicates its objectives and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through channels such as a post on DLLP's intranet site or email. Additionally, responsibilities for internal controls are communicated to appropriate users by various methods, including, but not limited to, email, live meetings, conference calls, and webcasts. All-hands meetings run by the CIO and conference calls are held to address responsibilities within DT-US. The responsibilities for compliance with policies are set out in a Policy Awareness Statement, which DLLP professionals are required to be acknowledged at least once per year. Various security awareness campaigns are conducted across the Deloitte U.S. Firms. Alerts are communicated to stakeholders via an internal portal. Appropriate users are notified directly by email for any time-sensitive matters.

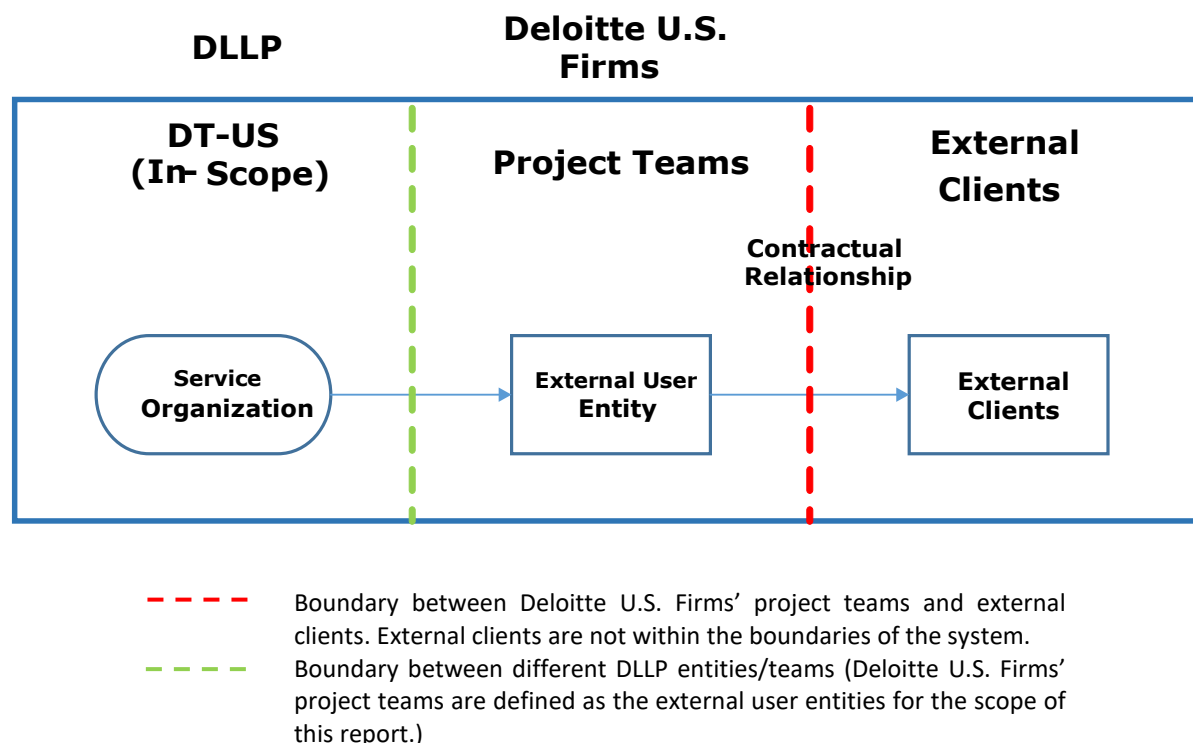
As required by their charters, the Board committees are required to formally report to the Board on their activities.

External Communication

When the Deloitte U.S. Firms' project teams have contractual relationships with external third parties, the external third parties are considered the external clients. DT-US itself is not a contractual party to the external clients.

Open communication channels such as a client inquiry mailbox, 1-800-Deloitte, the Deloitte.com contact form, and the online portal allow input from customers, consumers, suppliers, external auditors, regulators, financial analysts, and others. DLLP provides an Information Security Statement to clients and prospective clients when requested to provide an overview of IT security and availability practices and commitments.

The graphic below describes the boundaries between DT-US, Deloitte U.S. Firms' project teams, and external clients.



Policies and Procedures

DLLP has documented policies and procedures that establish what is expected and required of its professionals. These policies include guidelines for administrative activities, appropriate use of DLLP assets, talent policies, operational policies, and security requirements and guidelines for the use of assets and systems while working onsite in DLLP offices and while teleworking. These APRs are available on DLLP's intranet site and can be accessed at any time. On an as-needed basis, the Managing Director of Administrative Policy formally approves all individual substantive policy updates provided by the Manager of Administrative Policy before they are posted on DLLP's intranet site.

DLLP maintains a comprehensive information security program, which includes policies, standards, procedures, and guidelines. This program, which is the responsibility of DLLP's CIO, is influenced by several industry guidelines and leading practices, including International Organization for Standardization ISO 27001, 27017, 22301, Control Objectives for Information and Related Technologies (COBIT), Information Technology Infrastructure Library (ITIL), National Institute of Standards and Technology (NIST), the American Institute of Certified Public Accountants (AICPA) SSAE 18, and the Shared Assessments Program.

DLLP's IT leaders meet on a regular basis to consider strategic and tactical direction for the information security policies, standards, procedures, and guidelines.

The information security policy is drafted with input from internal cyber security resources and is based on industry-leading practices. The draft is reviewed and approved at least annually by DLLP's DT-US Cyber Security leadership, the Office of General Counsel, and the Confidentiality and Privacy group. Once approved, the policy is published on DLLP's intranet and communicated to professionals.

Written processes and procedures for operations and security are provided to the professionals responsible for operation of the system. Designated professionals update the processes and procedures manuals based on changes to availability requirements and security policies.

Logical Access Management

Network Access Controls

DLLP has implemented industry standard Network Access Controls (NAC) to prevent unauthorized devices from accessing the DLLP network. The NAC and group policy settings enforce compliance checks and authentication of DLLP managed devices for wired and wireless access. A firewall and intrusion prevention system (IPS) is employed at the point of entry to the DLLP network and between various security zones within the DLLP network. Access control lists are placed on firewalls controlling the inbound and outbound flow of traffic. Traffic is denied by default unless approved by the gateway protocols as configured and approved by the DLLP security team. A demilitarized zone (DMZ) and trusted zones are used to segment traffic to areas that are protected in accordance with the accepted risk levels. Web servers located on a publicly reachable network segment are separated from the internal network by a firewall (i.e., DMZ). DLLP's wireless network is encrypted and restricted to DLLP-managed devices.

Access Control – Network Appliances and Operating System

The production environment is logically segregated from non-production through separate non-production (i.e., development, staging) and production servers for each system.

Access to DLLP information contained on DLLP IT systems is granted on the principle of least privilege and need-to-know basis and is approved by the DLLP data owner. DLLP has policies and procedures in place to manage user accounts and access for new hires, existing staff, transfers, and terminated professionals. Automated processes link the Human Resource (HR) system to administer user access. Appropriate vendor and contractor access is granted on a temporary basis via a formal approval procedure. Upon approval, the vendor user accounts are created in a controlled domain organizational unit giving the access necessary to perform their defined duties. Vendor and contractor access are granted on a temporary basis based on business need. Remote access is provided via Transport Layer Security (TLS) using two-factor authentication with account activity being logged to DLLP's logging/alerting mechanism. Depending on the level and type of access required, a Virtual Private Network (VPN) solution provides a secure virtual session or web interface with access into the needed application(s) or platform. For all web-based applications (including VPN), Multi-Factor Authentication (MFA) has been enabled. Verification options include text message or mobile application. End users are assigned unique user IDs for access to the network. User accounts are disabled after 90 days of inactivity and deleted upon an additional 30 days of inactivity. Windows AD accounts on the primary domain are disabled using Microsoft Identity Manager (MIM) via an automated process on the day of termination. Once deleted from the network, a user ID cannot be reused for two years. Upon a user's job transfer, management uses the MAC tool to de-provision access that is no longer needed. Upon marking a user to be deprovisioned, the MAC tool automatically runs a job to de-provision users. In the event that a failure occurs, a ticket is opened to manually de-provision the access. Failed deprovisioned transactions are also reviewed weekly, and action is taken to resolve the failed transactions timely.

Privileged access requires a separate privileged user account, which is only used for administrative activities and not used for other general user activities. Privileged user accounts are established and administered in accordance with a role-based access scheme that organizes all system and network privileges into role-based groups (e.g., key management, network, system administration, database administration, and web administration).

The privileged account provisioning process requires approvals from a user's supervisor as well as data owners. Privileged access is managed by a privileged access management solution (PAM) that requires a user to be on the DLLP network and authenticate using multi-factor authentication (MFA). The tool also requires the user to check out the privileged account password, which is randomly generated every 24 hours. Privileged accounts are disabled after 30 days of inactivity and are removed manually within two days of termination. Privileged account activities are logged, logs are stored in a centralized log management solution, and activities are subject to review based on the rules defined within the SIEM tool.

Identification and Authentication

Users must authenticate to the DLLP network using a unique user identification (ID) and a strong password prior to gaining access to the information system.

DLLP applications and systems are managed by an enterprise Identity and Access Management (IAM) platform to centrally manage accounts, authentication, authorization, and access reviews. Users must authenticate to the DLLP network using one of the following methods:

- DLLP-managed device and a combination of unique user identification (ID) and a strong password
- DLLP-managed device and a combination of hardware-backed cryptographic authentication and a PIN, facial recognition, or fingerprint, satisfying multi-factor authentication (MFA)

DLLP systems are protected by strong password settings that require a history of 24 previous passwords, minimum password length of 10 characters, password complexity, password expiration no longer than 90 days, and lockout after six invalid attempts enabled for accounts. Users are required to use MFA when accessing the DLLP network, infrastructure, and applications.

Access Control – Review

On a semiannual basis, a review is performed and documented of all users with privileged access to servers. Any identified access issues are tracked and resolved in a timely manner. As part of the user access review process, owners complete the UAR within the MAC tool. Access is either re-confirmed or marked for de-provisioning. Upon marking a user to be de-provisioned, the MAC tool automatically runs a job to de-provision users. In the event that a failure occurs, a ticket is opened to manually de-provision the access. Failed deprovisioned transactions are also reviewed weekly, and action is taken to resolve the failed transactions timely.

Physical Security and Environmental Controls

Badge readers are installed to restrict physical access to the Hermitage Data Center, USI communication rooms, and USM communication rooms using C-Cure badge readers. Only authorized professionals with a DLLP-issued electronic badge are granted access to DLLP's facilities. Procedures exist for controlling visitor access and maintaining a detailed log of all visitors to the facilities. DLLP data centers are further restricted to only those professionals with the need to access these restricted areas. Hardware and network devices reside within the Hermitage Data Center, the USI communication rooms, and USM communication rooms in secured areas. DLLP data centers are defined by management as secured areas.

Management approves access to the Hermitage Data Center, USI communication rooms, USM communications rooms based on job function before access is granted. Once a user has been terminated or transferred, the user's access is removed manually within two business days. A quarterly review of access to the Hermitage Data Center is performed by the Data Center Manager, and a quarterly review of access to the USM communication rooms and USI communication rooms is performed by the Communication Room Manager.

The Hermitage Data Center is guarded by security guards 24/7. To enter the Hermitage Data Center, one must have badge access to the external front door as well as badge access to a set of man-trap doors. Additional physical security controls are in place for entry to the computer room, including a bio-metric reader and a PIN keypad. The USI communication rooms and USM communication rooms are guarded by 24/7 perimeter security and 24/7 building security. To enter the USI communication rooms and USM communication rooms, one must have badge access to the external front door as well as the door to the communication room. To enter the door to the communications room, a user must use their badge and PIN keypad. Procedures have been documented for controlling visitor access to all facilities. All visitors must be escorted and must sign in before and sign out after each visit. A detailed log of visitors to the Hermitage Data Center and USI communications rooms and USM communication rooms are maintained for audit or investigative purposes. Video cameras are positioned throughout the data center facilities to monitor activity.

The electricity, water, and temperature controls are pre-approved for use by the facilities administrators in the data centers. Temperature and humidity controls have been implemented to protect against temperature fluctuations in areas of the data centers containing IT equipment. Automatic pre-action hydronic fire suppression systems have been installed to protect the data centers. They will automatically deploy based on a defined temperature threshold. Master water shut-off valves are present throughout the facility. Emergency exits are located throughout the data center.

DLLP professionals are required to comply with a clean desk and clear screen policy for unattended work areas. Unattended laptops must be physically secured and locked with a password when not in use. Unassigned equipment is stored in a secured area when not in use, and hardware (laptops and servers) awaiting decommissioning is stored in a secured area until the hard disk drives are securely wiped and the device is returned to the vendor.

Vulnerability Management

DT's Cyber Defense team performs annual penetration testing and regular vulnerability scans across the infrastructure. Internal networks and the external perimeter are scanned monthly for vulnerabilities by the Cyber Defense team. Detected vulnerabilities are reviewed and remediation or risk acceptance is completed timely within three months. A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.

Cyber Security Incident Management

DLLP's integrated Incident Response team brings together the appropriate subject matter specialists from various cross-functional disciplines to address each specific incident. The Security Incident Response Procedures ("Procedures") describe how various types of incidents are handled. The Procedures describe the escalation path for incidents and identify key resources and communications, based on incident types and severity levels, as well as to whom suspected incidents should be reported. Security awareness training is in place to make DLLP professionals aware of their responsibilities concerning the reporting of security incidents. Each incident is logged, and the relevant facts are documented. When necessary, data related to the incident is maintained and an appropriate chain of custody is documented.

An information security incident management policy is maintained, reviewed, and approved at least every 12 months; a revision history is also maintained. The policy includes organization structure, response procedures, timelines for incident resolution, and guidance for the communication of incidents (including operational impact, timeline, and cost). The policy requires that changes to the system follow the established change management policy. At the completion of each significant incident, a post-incident review is conducted to identify any areas for improvement in the incident management procedures.

For high-severity security incidents, a root cause analysis is conducted and discussed with Risk Management. Based on the root cause analysis, change requests are prepared and the Risk Management process and relevant risk management data are updated to reflect the planned incident and problem resolution.

Network Security

Intrusion Detection and Prevention Systems (IDS/IPS) and network configurations, including firewall rules, are in place on the network and are updated for the latest rule set on a regular basis. New firewall rules or changes to existing firewall rules are approved before they are implemented. Network scans are performed periodically to identify issues, which are remediated based on level of criticality. Remediation performed is validated during the next network scan.

Anti-virus and Anti-malware Management

Anti-virus and anti-malware detection software is implemented on DLLP laptops and servers and is updated daily. Anti-malware alerts are reviewed individually on a risk-prioritized basis to identify potential malware activity. The Technology Support Services (TSS) group reviews the Compliance Dashboard for laptops not in compliance and resolve the identified issues. The anti-virus software is configured to automatically update protection periodically and scan the files prior to access. An Advanced Threat Protection (ATP) service has been deployed to provide protection against common and sophisticated attacks against DLLP-managed servers and laptops. The ATP service performs three primary functions: monitor, prevent / protect, and report.

Configuration Management

DLLP identifies, inventories, classifies, and manages an asset inventory in the CMDB within ServiceNow®. Assets have a designated owner who is responsible for asset management. Secure systems configuration standards are defined for systems used within the environment. Changes to hardening standards are reviewed and approved by Directors or Managers in the Infrastructure Management team. A standard build is used for professional's laptops that include: software firewall, anti-virus software, anti-spyware software, encryption software, backup software, data loss prevention (DLP) software, and a software distribution tool to apply the most recent approved operating system patches.

Change Management

DLLP has a change management process in place for its IT systems, including changes to the network, firewalls, and servers. This change management process has standardized methods, processes, and procedures that facilitate efficient and prompt handling of changes, including maintaining the proper balance between the need for the change and the potential detrimental impact of the change. Relevant changes are documented, tested, and approved prior to implementation in production. Each change request documents the change plan, impact assessment, backout plan, and post-implementation verification. Emergency changes follow a similar process; however, testing and approval may be documented within seven business days after the implementation.

Changes are reviewed and approved by the Change Advisory Board (CAB) prior to implementation. The CAB reviews these changes during regularly scheduled meetings, which include the CTO and the members of DLLP responsible for the security and availability commitments and requirements. Approved changes are tested. Deployment windows are scheduled to deploy non-emergency changes during non-peak hours.

Access to implement changes to the production environment is appropriately restricted. Changes are communicated to appropriate data owners. Changes that affect system user responsibilities or DLLP's commitments and requirements relevant to security and availability are communicated through email messages to impacted users as well as alerts posted to the internal professional's site.

Patch Management

DT-US maintains a patch management program supported by dedicated tools, overseen by an internal Patch Management Team (PMT). The PMT is composed of members of the DT-US Cyber Security Team. The US Cyber Security team actively monitors vendor and industry-accepted alert lists for newly released patches. During regularly scheduled meetings, the PMT reviews these patches and assigns deployment priorities based on assessed severity. For each monthly patch cycle, a change request is documented and approved. The patches are first applied to a group of test servers before being deployed to production. Server patches are implemented within three months of the vendor release. Emergency patch management meetings are convened as necessary.

Logging and Monitoring

DT-US and DT have various tools and processes in place to monitor the security, availability, and performance of its core infrastructure components. System audit logs are captured by the Cyber Security Operations team and retained for one year.

Security Event Monitoring

DT's 24X7 Security Operation Center uses an industry standard Security Information and Event Management (SIEM) platform and log monitoring tools to continuously identify, prevent, and respond to operational problems, security incidents, policy violations, and fraudulent activities. System audit logs are aggregated, and security events are analyzed with appropriate correlation rules to generate alerts and respond accordingly.

The Cyber Security Operations team has deployed a log management and analysis tool in the DLLP environment that aggregates logs from appliances and monitoring tools and analyzes them against a defined set of rules configured to monitor for security events and trigger alerts.

Security alerts and administrative activity are monitored by the Security Operations Center. Rules are set up to monitor for and alert DT professionals of unusual user activity and changes to server security configurations. The Splunk Forwarding Agent is installed on servers and Splunk is configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Alerts are investigated by DT professionals and issues are communicated to impacted parties.

Firewall IDS/IPS security events are monitored by the DT Security Operations Center and issues are remediated in a timely manner.

Availability Monitoring

The SRC monitors the infrastructure (e.g., network availability, servers, and firewalls) for system availability alerts, analyzes system activity, investigates alerts, and remediates issues in a timely manner.

Processing Capacity and Usage

Performance reports are initiated through automated tools that specify certain levels of performance to trigger the generation of these reports (e.g., % of CPU processor utilization, etc.). Future system performance, availability, and capacity requirements are projected and analyzed as part of the annual IT planning and budgeting process.

Data Encryption

Client data hosted on DLLP infrastructure is encrypted at rest. DLLP-issued laptops are encrypted using 256-bit AES whole-disk encryption and professionals are required to use DLLP-approved encryption methods when transmitting confidential data. WinZip and Rights Management are installed on all DLLP-issued laptops. These encryption methods are FIPS 140-2 compliant. In addition, authentication credentials transmitted to network devices are encrypted in transit. Laptops are configured to block the use of removable media.

Mobile devices must have the mobile device management (MDM) software installed and be enrolled in the MDM solution to access the DLLP network. The MDM software encrypts the device, isolates, and protects DLLP data, requires a PIN, enforces screen lockout after inactivity, enforces operating system updates, and remotely wipes the device after 10 incorrect PIN attempts or if the device is reported lost or stolen.

Data Storage and Retention

A records and information management program is in place, which includes applicable record retention schedules defined and classified by record types, retention periods, and the type of allowable storage media for each. The Records Retention policy defines professional's adherence to data retention period(s) as per established policies and procedures, and applicable legal, statutory, or regulatory compliance obligations. The policy is updated annually. Official records are archived and retained in the records management system in accordance with the Records Retention policy.

Data Sharing

The Data Classification and Handling policy defines all non-public client data as confidential. Confidential information is not shared with third parties unless a confidentiality agreement has been signed by the recipient. Access to confidential data is provisioned only after the data owner's approval.

Data Backup and Recovery

Production servers are scheduled for a daily incremental backup. If the backup fails for any reason, it will send out an alert and automatically retry to backup three times. If the backup fails more than four times, an incident ticket is opened in ServiceNow and tracked for resolution.

In the normal operation of the data center, disk-based backup restores are performed multiple times per week. These restores validate the integrity of backup data at rest on disk. Media assets (laptops or hard drives) that are unable to be wiped by DLLP are sent to a third party for destruction, and DLLP tracks and stores the destruction report as proof that the media asset was destroyed. Backup data stored on disk is encrypted using AES-256 standards.

Disaster Recovery/Business Continuity Management

While the goal of the overall Business Continuity Management program is to reduce the likelihood of a disruption, DLLP has developed and implemented a DR/Business Continuity Program (BCP) that enables the recovery of DLLP managed IT services so that the end-to-end business process can continue should a disruption occur. DLLP's program includes the following basic activities:

- Conducting a business impact assessment to help define criticality of processes and systems related to recovery time objective. Critical technology services are defined as Platinum, Gold, Silver or Tier 0, Tier 1, Tier 2 and Tier 3.
- Disaster recovery planning of our technology through multiple recovery capabilities.
- Performing a risk assessment for each of the DLLP Managed IT services to identify the business criticality, service dependencies and supporting service resilience architecture.
- Evaluating the options for recovery; producing a contingency/DR plan for critical technology services; and testing, reviewing, and revising that contingency plan on a regular basis.
- Business continuity test plans for DLLP Managed IT services are scoped and the problems identified are documented with an associated remediation action. The BCP or DR plan is reviewed and approved annually and tested on an annual basis as needed. A Business Impact Assessment (BIA) is performed each fiscal year to identify threats to software, hardware, people, and physical assets.
- Internal review process for maintaining the quality of plans and services.
- For server infrastructure that is administered by DT-US, a BCP/DR plan is in place for technical services using the server.
- The BCP and plans include emergency-response business procedures, which go into effect following the occurrence of a disaster or other unplanned interruption.
- DR plans include technical and business contact call lists, as well as notification and escalation information and architecture diagrams. Where pertinent, third-party information is also included. Recovery time objectives and recovery point objectives are documented and tested for each plan.
- Risk assessment test scenarios are based on impacts that include loss of the service and loss of data center strategy. Test results are reviewed and recorded.

COMPLEMENTARY USER ENTITY CONTROLS

Certain service commitments and system requirements specified in the description can be achieved only if complementary user entity controls contemplated in the design of DLLP and DTL's controls are suitably designed and operating effectively, along with related controls at the service organization. The system herein was designed with the assumption that certain controls will be implemented by external user entities. Such controls are called complementary user entity controls. The list below should not be regarded as a comprehensive list of all internal controls that should be implemented by the user entity, nor do they represent procedures that may be necessary in all circumstances. External user entities for this report are also referred to as the "external users."

Complementary User Entity Controls	Related Trust Criteria
User entities should have controls in place to ensure DT-US is backing up their servers and performing restoration testing, and that their data retention requirements are met by DT-US.	A1.2, A1.3
User entities should have controls in place to ensure that availability alerts delivered by DT-US are addressed in a timely manner and that they inform DLLP about issues or incidents related to their assets' availability.	A1.2, A1.3
User entities should have controls in place to ensure that availability is monitored and DLLP is informed of any issues or incidents related to the infrastructure supporting their applications and databases' availability.	CC7.2, CC7.3, CC7.4, CC7.5, A1.2, A1.3



TRUST SERVICES CRITERIA AND RELATED CONTROLS

Relevant trust services criteria and DLLP and DTL's related controls are included in Section V of this report, "Trust Services Criteria, Deloitte LLP and Deloitte Technology Limited's Controls, and KPMG LLP's Test of Controls and Results of Tests." Although the applicable trust services criteria and related controls are presented in Section V, they are, nevertheless, an integral part of DLLP and DTL's system description.

V. TRUST SERVICES CRITERIA, DELOITTE LLP AND DELOITTE
TECHNOLOGY LIMITED'S CONTROLS, AND KPMG LLP'S TEST
OF CONTROLS AND RESULTS OF TESTS

KPMG LLP'S TEST PROCEDURES

KPMG LLP's tests of the effectiveness of controls included such tests as were considered necessary in the circumstances to evaluate whether those controls were sufficient to provide reasonable, but not absolute, assurance that Deloitte LLP's service commitments and system requirements were achieved based on the trust services criteria relevant to security and availability and controls operated effectively throughout the period October 1, 2024 to September 30, 2025. In selecting particular tests of the operating effectiveness of controls, the following were considered: (a) the nature of the items being tested; (b) the types and competence of available evidential matter; (c) the nature of the criteria to be met; and (d) the expected efficiency and effectiveness of the test. Our procedures included inquiry of management, supervisory, and staff professionals; inspection of documents and records; and observation of activities and operations and test of controls.

In addition, when using information produced by DLLP and DTL, our procedures included an evaluation of the reliability of such information for our purposes by obtaining evidence of its completeness and accuracy.

SECURITY AND AVAILABILITY CATEGORIES AND CRITERIA AND RELATED CONTROLS

1.0 CONTROL ENVIRONMENT

Common Criteria 1.1 (COSO Principle 1)			
The entity demonstrates a commitment to integrity and ethical values.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-55	DLLP's Code outlines guidelines for professionals' ethical behavior and includes a sanctions policy for those who violate the Code.	Inspected DLLP's Code and determined that it outlined guidelines for professionals' ethical behavior and included a sanctions policy for professionals who violate the Code.	No exceptions noted.
DEL-66	Professionals are required to read and accept the Code within 90 days of hire.	Inspected the Code confirmation for a selection of new professionals and determined that the Code was accepted within 90 days of hire.	No exceptions noted.
DEL-68	Professionals are required to read and accept the Code annually.	Inspected the Code confirmation for a selection of existing professionals and determined that the Code was accepted.	No exceptions noted.
DEL-13	DLLP communicates its objectives related to security, availability, and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through various channels such as posts on DLLP's intranet site or email.	Observed DLLP's intranet site and noted that DLLP communicated its objectives and changes to objectives through posting on DLLP's intranet site. Inspected DLLP's intranet site and/or an email for a selection of changes to objectives and determined that DLLP communicated changes to objectives.	No exceptions noted.
DEL-14	DLLP has documented policies and procedures that establish what is expected and required of its professionals. These APRs are available on DLLP's intranet site and can be accessed at any time.	Inspected a selection of APRs and determined that they established the expectations and requirements of its professionals. Observed DLLP's intranet site and noted that APRs were available to professionals.	No exceptions noted.

Common Criteria 1.1 (COSO Principle 1)

The entity demonstrates a commitment to integrity and ethical values.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
DEL-24	Standard contract templates, including service levels and compliance, privacy, and confidentiality requirements, are used for third-party vendors as necessary based on the service provided and deviations from those are reviewed and approved by key stakeholders.	Inspected the standard contract template for third-party vendors and determined that a template was in place for third-party vendors, as necessary based on the service provided, and included service levels and compliance, privacy, and confidentiality requirements. Inspected the contract for a selection of third-party vendors and determined that deviations from the contract template were reviewed and approved by key stakeholders.	No exceptions noted.
DEL-7	Deloitte's U.S. legal structure consists of the following legal entities: Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which has a defined organization leadership with National Managing Partners/Principals. Each of the legal entities has representation on the Board.	Inspected Deloitte's U.S. legal structure on Deloitte.com and determined that it consisted of Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which had a defined organization leadership with National Managing Partner/Principals. Furthermore, inspected the Deloitte Transparency Report on DLLP's intranet site and determined that each legal entity had representation on the Board.	No exceptions noted.
DEL-8	The Board operates through seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, and work with management and the full Board. Internal control deficiencies are communicated to the Board via the Board committees.	Inspected the organizational chart of the Board and the seven Board committees and determined that the Board committees reported to the full Board. Inspected the Board biographies and determined that the Board member biographies indicated areas of specialization. Inspected communications between the Board and Board committees and determined that the Board committees formally reported their activities, including communication of internal control deficiencies to the Board.	No exceptions noted.

Common Criteria 1.2 (COSO Principle 2)

The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-7	Deloitte's U.S. legal structure consists of the following legal entities: Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which has a defined organization leadership with National Managing Partners/Principals. Each of the legal entities has representation on the Board.	Inspected Deloitte's U.S. legal structure on Deloitte.com and determined that it consisted of Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which had a defined organization leadership with National Managing Partner/Principals. Furthermore, inspected the Deloitte Transparency Report on DLLP's intranet site and determined that each legal entity had representation on the Board.	No exceptions noted.
DEL-8	The Board operates through seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, and work with management and the full Board. Internal control deficiencies are communicated to the Board via the Board committees.	Inspected the organizational chart of the Board and the seven Board committees and determined that the Board committees reported to the full Board. Inspected the Board biographies and determined that the Board member biographies indicated areas of specialization. Inspected communications between the Board and Board committees and determined that the Board committees formally reported their activities, including communication of internal control deficiencies to the Board.	No exceptions noted.

Note: DLLP is a private company and there is no requirement for the Board to be independent of management. As DLLP is structured as a partnership, all members of the Board are Partners or Principals of the Deloitte U.S. Firms representing the individual legal entities. They demonstrate independence while exercising oversight of the development and performance of internal control.

Common Criteria 1.3 (COSO Principle 3)

Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-7	Deloitte's U.S. legal structure consists of the following legal entities: Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which has a defined organization leadership with National Managing Partners/Principals. Each of the legal entities has representation on the Board.	Inspected Deloitte's U.S. legal structure on Deloitte.com and determined that it consisted of Deloitte & Touche LLP, Deloitte Consulting LLP, Deloitte Tax LLP, Deloitte Financial Advisory Services LLP, and Deloitte Transactions and Business Analytics LLP, each of which had a defined organization leadership with National Managing Partner/Principals. Furthermore, inspected the Deloitte Transparency Report on DLLP's intranet site and determined that each legal entity had representation on the Board.	No exceptions noted.
DEL-8	The Board operates through seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, and work with management and the full Board. Internal control deficiencies are communicated to the Board via the Board committees.	Inspected the organizational chart of the Board and the seven Board committees and determined that the Board committees reported to the full Board. Inspected the Board biographies and determined that the Board member biographies indicated areas of specialization. Inspected communications between the Board and Board committees and determined that the Board committees formally reported their activities, including communication of internal control deficiencies to the Board.	No exceptions noted.
Infrastructure			
INF-1	Roles and responsibilities related to the security and availability professionals are defined and documented.	Inspected the Cyber Security Standards document and determined that the roles and responsibilities related to security and availability professionals were defined and documented.	No exceptions noted.

Common Criteria 1.3 (COSO Principle 3)

Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-2	The CISO is responsible for security, including the design, development, implementation, operation, maintenance, monitoring, and approval of the entity's system controls and other risk mitigation strategies for the system. The Cyber Security Strategy leader, Security Operations leader, and Risk and Compliance leader report to the CISO. The organizational chart is reviewed by DT-US Business Operations on an annual basis.	Inspected the organizational charts and determined that the teams responsible for security were reviewed and updated on an annual basis (within the past 12 months) and determined that the Cyber Security Strategy leader, Security Operations leader, and Risk and Compliance leader reported to the CISO.	No exceptions noted.
INF-4	The T&I organization, under the CTO, is responsible for availability, including the design, development, implementation, operation, maintenance, monitoring, and approval of the entity's system controls and other risk mitigation strategies for the system. The organizational charts are reviewed by DT-US Business Operations on an annual basis.	Inspected the DLLP Organizational Chart and determined that the organizational chart was reviewed within the year and the T&I organization was responsible for availability, including the design, development, implementation, operation, maintenance, monitoring and approval of the entity's system controls and other risk mitigation strategies for the system.	No exceptions noted.

Common Criteria 1.4 (COSO Principle 4)

The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-6	Minimum education and prior work experience are documented as part of the hiring requirements for professionals responsible for designing, developing, implementing, operating, maintaining, and monitoring the security and availability of the system.	Inspected job descriptions and primary qualifications for a selection of job postings related to DT-US professionals who were responsible for designing, developing, implementing, operating, maintaining, and monitoring the security and availability of the system and determined that the job descriptions defined the minimum education and/or prior work experience requirements for the position.	No exceptions noted.
DEL-12	The background investigation policy for US, USI, and USM includes verification of identity, employment, education, and criminal record.	Inspected the background investigation policy for US, USI, and USM and determined that it included verification of identity, employment, education, and criminal record.	No exceptions noted.
DEL-5	New hires undergo security awareness training within 90 calendar days of hiring.	Inspected the date of security awareness training for a selection of new hires and determined that each selected new hire completed the security awareness training within 90 calendar days of hiring.	No exceptions noted.
DEL-32	Professionals undergo security awareness training annually.	Inspected the date of security awareness training for a selection of professionals and determined that each selected professional completed the updated security awareness training annually.	No exceptions noted.
DEL-4	Developers are required to complete annual application security developer training and pass an exam upon completion once every calendar year.	Inspected the application security developer course completion exam results for a selection of application developers and determined that the developers successfully passed the application security developer exam upon course completion within the past 12 months.	No exceptions noted.
DEL-67	The performance of professionals responsible for security and availability is reviewed on an annual basis by the individual's coach.	Inspected the performance management report and determined that at least one snapshot review was completed by the individual's coach within the past 12 months for a selection of professionals responsible for security and availability.	No exceptions noted.

Common Criteria 1.4 (COSO Principle 4)

The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
DEL-1	Senior management and the Board have developed contingency plans for assignments of responsibility for internal controls.	Inspected the contingency plans and determined that they included assignments of responsibility for internal controls.	No exceptions noted.
DEL-2	DLLP provides compliance and role-based training opportunities to professionals.	Inspected the training portal and determined that DLLP provided compliance and role-based training opportunities to professionals.	No exceptions noted.
DEL-14	DLLP has documented policies and procedures that establish what is expected and required of its professionals. These APRs are available on DLLP's intranet site and can be accessed at any time.	Inspected a selection of APRs and determined that they established the expectations and requirements of its professionals. Observed DLLP's intranet site and noted that APRs were available to professionals.	No exceptions noted.
Infrastructure			
INF-1	Roles and responsibilities related to the security and availability professionals are defined and documented.	Inspected the Cyber Security Standards document and determined that the roles and responsibilities related to security and availability professionals were defined and documented.	No exceptions noted.

Common Criteria 1.5 (COSO Principle 5)

The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-55	DLLP's Code outlines guidelines for professionals' ethical behavior and includes a sanctions policy for those who violate the Code.	Inspected DLLP's Code and determined that it outlined guidelines for professionals' ethical behavior and included a sanctions policy for professionals who violate the Code.	No exceptions noted.
DEL-67	The performance of professionals responsible for security and availability is reviewed on an annual basis by the individual's coach.	Inspected the performance management report and determined that at least one snapshot review was completed by the individual's coach within the past 12 months for a selection of professionals responsible for security and availability.	No exceptions noted.
DEL-14	DLLP has documented policies and procedures that establish what is expected and required of its professionals. These APRs are available on DLLP's intranet site and can be accessed at any time.	Inspected a selection of APRs and determined that they established the expectations and requirements of its professionals. Observed DLLP's intranet site and noted that APRs were available to professionals.	No exceptions noted.
DEL-25	DLLP has a formal Rewards and Recognition program to provide rewards and incentives to professionals.	Inspected DLLP's intranet site and determined that a Rewards and Recognition program existed that provided rewards and incentives to professionals.	No exceptions noted.
Infrastructure			
INF-1	Roles and responsibilities related to the security and availability professionals are defined and documented.	Inspected the Cyber Security Standards document and determined that the roles and responsibilities related to security and availability professionals were defined and documented.	No exceptions noted.

2.0 COMMUNICATION AND INFORMATION

Common Criteria 2.1 (COSO Principle 13) The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-22	Internal control deficiencies identified via IT assessments are communicated to management and tracked to resolution.	Inspected communication documentation and determined that internal control deficiencies identified via IT assessments were communicated and tracked to resolution.	No exceptions noted.
DEL-26	Internal audits are performed based on the annual risk-based internal audit plan.	Inspected the DT-US Audit and Assessments plan and a selection of DT-US Audit reports covering DLLP's fiscal year ending 5/31/25 and determined that internal audits related to security and availability were performed within the past 12 months.	No exceptions noted.
Infrastructure			
INF-24	Secure system configuration standards are defined and reviewed and approved annually for each type of server, laptop operating system, and network device within the system.	Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were defined. Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were reviewed and approved annually.	No exceptions noted.
INF-25	DLLP identifies, inventories, classifies, and manages an assets inventory in the CMDB. Assets have a designated owner who is responsible for asset management.	Inspected the inventory from the CMDB for a selection of servers and network devices and determined that DLLP identified, inventoried, classified, and managed the assets in the CMDB and had a designated owner who was responsible for asset management.	No exceptions noted.

Common Criteria 2.1 (COSO Principle 13)

The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-10	The information security and technology policies establish DLLP's objectives and internal and external users' responsibilities as they relate to the security and availability of information assets in accordance with applicable laws, regulations, and industry best practices. The policies are reviewed by the Policy and Compliance team and approved annually. The policies contain the following attributes: 1. Policy maintenance 2. Asset management, including information handling 3. Human resources 4. Physical and environmental security 5. Communications and operations management 6. Access control 7. Information systems acquisition, development and maintenance, including vulnerability management 8. Information security incident management 9. Business continuity management 10. Compliance with legal requirements	Inspected the information security and technology policies and determined that the policies were documented to establish DLLP's objectives and internal and external users' responsibilities related to the security and availability of information assets in accordance with applicable laws, regulations, and industry best practices. Inspected the information security and technology policies and determined that the policies contained the following attributes: 1. Policy maintenance 2. Asset management, including information handling 3. Human resources 4. Physical and environmental security 5. Communications and operations management 6. Access control 7. Information systems acquisition, development and maintenance, including vulnerability management 8. Information security incident management 9. Business continuity management 10. Compliance with legal requirements Inspected the information security and technology policies and determined that the policies were reviewed and approved annually by the Policy and Compliance team.	No exceptions noted.
INF-13	Written processes and procedures for operations and security are provided to professionals responsible for operation of the system. Designated professionals update the processes and procedures manuals based on changes to availability requirements and security policies.	Inspected a selection of operational and security-related procedure and process documents and determined that the documents were available to professionals, approved, and contained a version history.	No exceptions noted.

Common Criteria 2.2 (COSO Principle 14)

The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-4	Developers are required to complete annual application security developer training and pass an exam upon completion once every calendar year.	Inspected the application security developer course completion exam results for a selection of application developers and determined that the developers successfully passed the application security developer exam upon course completion within the past 12 months.	No exceptions noted.
DEL-2	DLLP provides compliance and role-based training opportunities to professionals.	Inspected the training portal and determined that DLLP provided compliance and role-based training opportunities to professionals.	No exceptions noted.
DEL-5	New hires undergo security awareness training within 90 calendar days of hiring.	Inspected the date of security awareness training for a selection of new hires and determined that each selected new hire completed the security awareness training within 90 calendar days of hiring.	No exceptions noted.
DEL-32	Professionals undergo security awareness training annually.	Inspected the date of security awareness training for a selection of professionals and determined that each selected professional completed the updated security awareness training annually.	No exceptions noted.
DEL-15	At least once per year, professionals are required to acknowledge their review and understanding of the security policies and the security awareness statement, which include how to report security and availability failures, incidents, concerns, and other complaints to appropriate professionals.	Inspected the security policy and security awareness statement and determined that they included instructions on how to report security and availability failures, incidents, concerns, and other complaints to specified professionals. Inspected the acknowledgement form for a selection of professionals and determined that the security policies and security awareness statement were acknowledged annually.	No exceptions noted.

Common Criteria 2.2 (COSO Principle 14)

The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
DEL-17	Professionals signify their acceptance of DLLP's acceptable use policy at least annually. Professionals have an additional 15-day grace period for compliance.	Inspected the Policy Awareness Statement acknowledgement for a selection of professionals and determined that the professional acknowledged the acceptable use policy within the past year.	No exceptions noted.
DEL-8	The Board operates through seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, and work with management and the full Board. Internal control deficiencies are communicated to the Board via the Board committees.	Inspected the organizational chart of the Board and the seven Board committees and determined that the Board committees reported to the full Board. Inspected the Board biographies and determined that the Board member biographies indicated areas of specialization. Inspected communications between the Board and Board committees and determined that the Board committees formally reported their activities, including communication of internal control deficiencies to the Board.	No exceptions noted.
DEL-11	DLLP maintains an ethics hotline that is facilitated by a third party.	Observed DLLP's intranet site and external site and noted that DLLP maintained an ethics hotline that was facilitated by a third party.	No exceptions noted.
DEL-13	DLLP communicates its objectives related to security, availability, and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through various channels such as posts on DLLP's intranet site or email.	Observed DLLP's intranet site and noted that DLLP communicated its objectives and changes to objectives through posting on DLLP's intranet site. Inspected DLLP's intranet site and/or an email for a selection of changes to objectives and determined that DLLP communicated changes to objectives.	No exceptions noted.
DEL-14	DLLP has documented policies and procedures that establish what is expected and required of its professionals. These APRs are available on DLLP's intranet site and can be accessed at any time.	Inspected a selection of APRs and determined that they established the expectations and requirements of its professionals. Observed DLLP's intranet site and noted that APRs were available to professionals.	No exceptions noted.

Common Criteria 2.2 (COSO Principle 14)

The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-1	Roles and responsibilities related to the security and availability professional are defined and documented.	Inspected the Cyber Security Standards document and determined that the roles and responsibilities related to security and availability professional were defined and documented.	No exceptions noted.
INF-9	Documentation of the use and description of the system is available to authorized users via the Information Security Statement.	Inspected the DLLP Information Security Statement and determined that the use and description of the system was available to authorized internal and external users via DLLP's intranet site.	No exceptions noted.
INF-19	Changes that affect system user responsibilities or DLLP's commitments and requirements relevant to security and availability are communicated to impacted users and alerts are posted to DLLP's intranet site.	Inspected a selection of email notifications distributed by Technology Services to users and DLLP's intranet site and determined that changes or issues that impact the system were communicated.	No exceptions noted.
INF-20	DLLP documents its boundaries with internal and external users through the security statement.	Inspected the DLLP security statement and determined that DLLP DT-US documented its boundaries with internal and external users in the security statement	No exceptions noted.

Common Criteria 2.3 (COSO Principle 15)

The entity communicates with external parties regarding matters affecting the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-11	DLLP maintains an ethics hotline that is facilitated by a third party.	Observed DLLP's intranet site and external site and noted that DLLP maintained an ethics hotline that was facilitated by a third party.	No exceptions noted.
DEL-20	Open communication channels such as the client inquiry mailbox, 1-800-Deloitte, Deloitte.com contact form, and the online portal allow input from customers, consumers, suppliers, external auditors, regulators, financial analysts, and others.	Inspected DLLP's intranet site and Deloitte.com and determined that open communication channels such as the client inquiries mailbox, 1-800-Deloitte, and the online portal allowed input from customers and external parties.	No exceptions noted.
DEL-21	Relevant information resulting from IT assessments conducted by external parties is communicated to leadership at least annually.	Inspected evidence of the IT assessments and communications and determined that relevant information resulting from IT assessments was communicated to leadership at least annually.	No exceptions noted.
DEL-13	DLLP communicates its objectives related to security, availability, and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through various channels such as posts on DLLP's intranet site or email.	Observed DLLP's intranet site and noted that DLLP communicated its objectives and changes to objectives through posting on DLLP's intranet site. Inspected DLLP's intranet site and/or an email for a selection of changes to objectives and determined that DLLP communicated changes to objectives.	No exceptions noted.
Infrastructure			
INF-12	DLLP provides an Information Security Statement to clients to provide an overview of DLLP's IT security and availability practices and commitments.	Inspected the Information Security Statement and determined that it provided an overview of DLLP's IT security and availability practices and commitments.	No exceptions noted.
INF-16	Policies and procedures are in place to communicate how external users are responsible for reporting security and availability issues, failures, and incidents through online support forms or their DLLP representative.	Inspected the DLLP intranet site and determined that the site informed the Deloitte U.S. Firms project teams of methods for reporting security and availability issues, failures, and incidents.	No exceptions noted.

Common Criteria 2.3 (COSO Principle 15)

The entity communicates with external parties regarding matters affecting the functioning of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-19	Changes that affect system user responsibilities or DLLP's commitments and requirements relevant to security and availability are communicated to impacted users and alerts are posted to DLLP's intranet site.	Inspected a selection of email notifications distributed by Technology Services to users and DLLP's intranet site and determined that changes or issues that impact the system were communicated.	No exceptions noted.

3.0 RISK ASSESSMENT

Common Criteria 3.1 (COSO Principle 6) The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-13	DLLP communicates its objectives related to security, availability, and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through various channels such as posts on DLLP's intranet site or email.	Observed DLLP's intranet site and noted that DLLP communicated its objectives and changes to objectives through posting on DLLP's intranet site. Inspected DLLP's intranet site and/or an email for a selection of changes to objectives and determined that DLLP communicated changes to objectives.	No exceptions noted.
Infrastructure			
INF-79	Controls are identified and reviewed annually based on a defined framework to mitigate risks and support the achievement of management's objectives.	Inspected the list of controls and the defined framework and determined that the controls, including IT general controls, were based on a defined framework to mitigate risks and support the achievement of management's objectives. Inspected the control review and determined that the Compliance Risk team and DT-US business owner reviewed the controls annually.	No exceptions noted.

Common Criteria 3.2 (COSO Principle 7)

The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-23	A formal risk governance program is implemented and includes a risk governance plan, risk policy and procedures, business assets to be evaluated, threat types, risk training, and risk evaluation criteria.	Inspected the risk governance program documents and determined that the risk governance program was formally documented and contained the risk policy and procedures, business assets to be evaluated, threat types, risk training, and risk evaluation criteria.	No exceptions noted.
DEL-27	On a quarterly basis, the Risk Committee meets to discuss changes in technology and the impact of applicable laws or regulations, including their effect on the entity's policies. The results of these meetings supplement DLLP's internal reporting requirements.	Inspected the meeting agenda for a selection of quarters and determined that the Risk Committee meetings occurred on a quarterly basis. Inspected the meeting materials, including the meeting agenda, the risk narrative, and risk dashboard, for a selection of quarters and determined that developments in technology and the impact of applicable laws or regulations were included in the meeting agendas.	No exceptions noted.
DEL-9	DLLP has established and assigned responsibility and accountability for the management of vendor/third-party risks. The Third-Party Security team performs third-party security assessments and re-assessments for contracted vendors are performed based on risk rating.	Inspected the latest third-party security assessment or re-assessment for a selection of vendors and determined that the Third-Party Security team was responsible for completing the assessment, and the assessment was completed based on risk rating.	No exceptions noted.
DEL-26	Internal audits are performed based on the annual risk-based internal audit plan.	Inspected the DT-US Audit and Assessments plan and a selection of DT-US Audit reports covering DLLP's fiscal year ending 5/31/25 and determined that internal audits related to security and availability were performed within the past 12 months.	No exceptions noted.
DEL-33	DLLP annually performs a "war games" tabletop exercise where top threat scenarios are selected, and senior leadership executes the BCP to practice for scenarios that could impair DLLP's ability to recover from various incidents.	Inspected the "war games" documentation and determined that the tabletop exercise was performed. Inspected the "war games" meeting invite and determined that the "war games" results were communicated to the CISO and CTO.	No exceptions noted.

Common Criteria 3.2 (COSO Principle 7)

The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-25	DLLP identifies, inventories, classifies, and manages an assets inventory in the CMDB. Assets have a designated owner who is responsible for asset management.	Inspected the inventory from the CMDB for a selection of servers and network devices and determined that DLLP identified, inventoried, classified, and managed the assets in the CMDB and had a designated owner who was responsible for asset management.	No exceptions noted.
INF-27	DT-US CSRC completes a risk assessment review annually to identify risks and associated mitigation procedures and controls.	Inspected the DT-US CSRC annual risk assessment and determined that the risk assessment included risks and associated mitigating controls, and review and approval. Inspected risk assessment documents and determined that risks that were determined to not be mitigated to an acceptable level were further reviewed for proper treatment and tracked to completion.	No exceptions noted.
INF-26	A site-level threat assessment is conducted each fiscal year of the actual threat environment to identify environmental or physical threat changes.	Inspected the most recent threat assessment for the Hermitage Data Center, USI communication rooms, and USM communication room and determined that the threat assessment included physical and environmental threats and was updated during the last fiscal year and approved by management.	No exceptions noted
INF-28	Vulnerability scans are conducted monthly on internal networks and the external perimeter to detect vulnerabilities. The detected vulnerabilities are reviewed, and remediation or risk acceptance is completed timely.	Inspected Qualys AssetView for a selection of devices and determined that the devices were running on Qualys. Inspected the internal vulnerability scans for a selection of months and devices and determined that the detected vulnerabilities were remediated, or risk accepted in a timely manner. Inspected the external vulnerability scans for a selection of months and devices and determined that detected vulnerabilities were remediated or risk accepted in a timely manner.	No exceptions noted.

Common Criteria 3.2 (COSO Principle 7)

The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-29	A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.	Inspected the Vulnerability Management Service presentation and the included vulnerability scan summary for a selection of months and determined that a summary of vulnerabilities was reported to Executive management monthly.	No exceptions noted.
INF-21	A BIA is performed each fiscal year to identify threats and document the likelihood and impact of identified threats to software, hardware, people, and physical assets.	Inspected the BIA and determined that a BIA was performed annually to identify threats to software, hardware, people, and physical assets.	No exceptions noted.

Common Criteria 3.3 (COSO Principle 8)

The entity considers the potential for fraud in assessing risks to the achievement of objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-16	On an annual basis, management completes a Fraud Risk Assessment in various processes within the Deloitte U.S. Firms, including the identification of fraud risks, schemes, and control activities.	Inspected the annual Fraud Risk Assessment for Deloitte U.S. Firms and determined that the risk assessment included the identification of fraud risks, schemes, and control activities.	No exceptions noted.

Common Criteria 3.4 (COSO Principle 9)

The entity identifies and assesses changes that could significantly impact the system of internal control.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-27	On a quarterly basis, the Risk Committee meets to discuss changes in technology and the impact of applicable laws or regulations, including their effect on the entity's policies. The results of these meetings supplement DLLP's internal reporting requirements.	Inspected the meeting agenda for a selection of quarters and determined that the Risk Committee meetings occurred on a quarterly basis. Inspected the meeting materials, including the meeting agenda, the risk narrative, and risk dashboard, for a selection of quarters and determined that developments in technology and the impact of applicable laws or regulations were included in the meeting agendas.	No exceptions noted.
DEL-9	DLLP has established and assigned responsibility and accountability for the management of vendor/third-party risks. The Third-Party Security team performs third-party security assessments and re-assessments for contracted vendors are performed based on risk rating.	Inspected the latest third-party security assessment or re-assessment for a selection of vendors and determined that the Third-Party Security team was responsible for completing the assessment, and the assessment was completed based on risk rating.	No exceptions noted.
DEL-1	Senior management and the Board have developed contingency plans for assignments of responsibility for internal controls.	Inspected the contingency plans and determined that they included assignments of responsibility for internal controls.	No exceptions noted.
Infrastructure			
INF-26	A site-level threat assessment is conducted each fiscal year of the actual threat environment to identify environmental or physical threat changes.	Inspected the most recent threat assessment for the Hermitage Data Center, USI communication rooms, and USM communication room and determined that the threat assessment included physical and environmental threats and was updated during the last fiscal year and approved by management.	No exceptions noted.

4.0 MONITORING ACTIVITIES

Common Criteria 4.1 (COSO Principle 16) The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-22	Internal control deficiencies identified via IT assessments are communicated to management and tracked to resolution.	Inspected communication documentation and determined that internal control deficiencies identified via IT assessments were communicated and tracked to resolution.	No exceptions noted.
DEL-26	Internal audits are performed based on the annual risk-based internal audit plan.	Inspected the DT-US Audit and Assessments plan and a selection of DT-US Audit reports covering DLLP's fiscal year ending 5/31/25 and determined that internal audits related to security and availability were performed within the past 12 months.	No exceptions noted.
Infrastructure			
INF-72	DLLP's ISMS is reviewed by an independent firm for ISO 27001, 27017, and 22301 certifications and the certifications are valid.	Inspected ISO 27001, 27017, and 22301 certification evidence and determined that DLLP's ISMS was reviewed by an independent firm and the certifications were valid.	No exceptions noted.

Common Criteria 4.2 (COSO Principle 17)

The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-8	The Board operates through seven committees. Board committees operate on behalf of the Board, as stewards of and specialists in particular areas, and work with management and the full Board. Internal control deficiencies are communicated to the Board via the Board committees.	Inspected the organizational chart of the Board and the seven Board committees and determined that the Board committees reported to the full Board. Inspected the Board biographies and determined that the Board member biographies indicated areas of specialization. Inspected communications between the Board and Board committees and determined that the Board committees formally reported their activities, including communication of internal control deficiencies to the Board.	No exceptions noted.
DEL-22	Internal control deficiencies identified via IT assessments are communicated to management and tracked to resolution.	Inspected communication documentation and determined that internal control deficiencies identified via IT assessments were communicated and tracked to resolution.	No exceptions noted.
DEL-26	Internal audits are performed based on the annual risk-based internal audit plan.	Inspected the DT-US Audit and Assessments plan and a selection of DT-US Audit reports covering DLLP's fiscal year ending 5/31/25 and determined that internal audits related to security and availability were performed within the past 12 months.	No exceptions noted.

5.0 CONTROL ACTIVITIES

Common Criteria 5.1 (COSO Principle 10) The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-79	Controls are identified and reviewed annually based on a defined framework to mitigate risks and support the achievement of management's objectives.	Inspected the list of controls and the defined framework and determined that the controls, including IT general controls, were based on a defined framework to mitigate risks and support the achievement of management's objectives. Inspected the control review and determined that the Compliance Risk team and DT-US business owner reviewed the controls annually.	No exceptions noted.

Common Criteria 5.2 (COSO Principle 11)

The entity also selects and develops general control activities over technology to support the achievement of objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-79	Controls are identified and reviewed annually based on a defined framework to mitigate risks and support the achievement of management's objectives.	Inspected the list of controls and the defined framework and determined that the controls, including IT general controls, were based on a defined framework to mitigate risks and support the achievement of management's objectives. Inspected the control review and determined that the Compliance Risk team and DT-US business owner reviewed the controls annually.	No exceptions noted.

Common Criteria 5.3 (COSO Principle 12)

The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-14	DLLP has documented policies and procedures that establish what is expected and required of its professionals. These APRs are available on DLLP's intranet site and can be accessed at any time.	Inspected a selection of APRs and determined that they established the expectations and requirements of its professionals. Observed DLLP's intranet site and noted that APRs were available to professionals.	No exceptions noted.

Common Criteria 5.3 (COSO Principle 12)

The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-10	The information security and technology policies establish DLLP's objectives and internal and external users' responsibilities as they relate to the security and availability of information assets in accordance with applicable laws, regulations, and industry best practices. The policies are reviewed by the Policy and Compliance team and approved annually. The policies contain the following attributes: 1. Policy maintenance 2. Asset management, including information handling 3. Human resources 4. Physical and environmental security 5. Communications and operations management 6. Access control 7. Information systems acquisition, development and maintenance, including vulnerability management 8. Information security incident management 9. Business continuity management 10. Compliance with legal requirements	Inspected the information security and technology policies and determined that the policies were documented to establish DLLP's objectives and internal and external users' responsibilities related to the security and availability of information assets in accordance with applicable laws, regulations, and industry best practices. Inspected the information security and technology policies and determined that the policies contained the following attributes: 1. Policy maintenance 2. Asset management, including information handling 3. Human resources 4. Physical and environmental security 5. Communications and operations management 6. Access control 7. Information systems acquisition, development and maintenance, including vulnerability management 8. Information security incident management 9. Business continuity management 10. Compliance with legal requirements Inspected the information security and technology policies and determined that the policies were reviewed and approved annually by the Policy and Compliance team.	No exceptions noted.
INF-13	Written processes and procedures for operations and security are provided to professionals responsible for operation of the system. Designated professionals update the processes and procedures manuals based on changes to availability requirements and security policies.	Inspected a selection of operational and security-related procedure and process documents and determined that the documents were available to professionals, approved, and contained a version history.	No exceptions noted.

6.0 LOGICAL AND PHYSICAL ACCESS CONTROLS

Common Criteria 6.1 The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-29	Mobile devices must have the MDM software installed and be enrolled in the MDM solution in order to access the DLLP network. The MDM software encrypts the device, isolates, and protects DLLP data and applications, requires a PIN, enforces screen lockout after inactivity, enforces operating system updates, and remotely wipes the device after 8 incorrect PIN attempts or if the device is reported lost or stolen.	Inspected the mobile device configuration and determined the mobile devices had the MDM software installed, were encrypted, required a PIN, enforced screen lockout after inactivity, enforced operating system updates, and in the event of 8 incorrect PIN attempts, the device would be remotely wiped.	No exceptions noted.
Infrastructure			
INF-25	DLLP identifies, inventories, classifies, and manages an assets inventory in the CMDB. Assets have a designated owner who is responsible for asset management.	Inspected the inventory from the CMDB for a selection of servers and network devices and determined that DLLP identified, inventoried, classified, and managed the assets in the CMDB and had a designated owner who was responsible for asset management.	No exceptions noted.
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.

Common Criteria 6.1

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-49	A standard build is used for professional's laptops that includes: software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches.	Inspected the standard build template for Windows 10 laptops and determined that the standard build included application of a software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches. Inspected the configuration for a selection of user laptops and determined that the laptops were configured in line with the standard build requirements.	No exceptions noted.
INF-80	A standard build is used for servers that includes: anti-virus software, a vulnerability scanning tool, passwords, a software distribution tool to apply the most recent approved operating system patches, and restriction of the ability to install and modify operating system and other system programs to authorized professionals.	Inspected the standard build for Windows and Linux servers and determined that the standard build included anti-virus software, a vulnerability scanning tool, passwords, a software distribution tool to apply the most recent approved operating system patches and the ability to install and modify operating system and other system programs to authorized professionals. Inspected the anti-virus agent, vulnerability scan agent, password settings, software distribution tool, and administrative user listings for a selection of servers and determined that the servers were configured in line with the standard build requirements.	No exceptions noted.
INF-71	The network is segmented between internal networks, firewall locations, and points of access. The virtual network diagram is configured to automatically update on a regular basis (at least weekly).	Inspected the virtual network diagram and determined that the network was documented, segmented by city, and included the points of access. Inspected the configuration and determined that the virtual network diagram was configured to automatically update on a regular basis (at least weekly).	No exceptions noted.

Common Criteria 6.1

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-35	In order for a professional to obtain remote network access, the connecting laptop must: • Be a recognized DLLP laptop. • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Observed a DLLP professional complete the VPN connection process and noted that it required a DLLP laptop and a valid user ID and password within AD for successful remote network access. Observed a DLLP professional attempt to login to the DLLP network without completing the VPN connection process and noted that the professional was unsuccessful. Inspected the VPN configuration for a DLLP professional and determined that it required both valid login credentials, a DLLP laptop, and MFA for successful professional remote network access.	No exceptions noted.

Common Criteria 6.1

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-45	Prior to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Pass a security scan. • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application. Subsequent to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Be connected to a DLLP configured VDI • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Inquired of management and were informed that the process for vendors and contractors to obtain remote network access changed on May 31, 2025. Subsequent to May 31, 2025: Observed a vendor or contractor complete the VDI connection process on their laptop and noted that it required both valid login credentials and MFA for successful vendor/contractor remote network access. Observed a vendor or contractor attempt to login to the DLLP network on their laptop without completing the VDI connection process and noted that the vendor/contractor was unsuccessful. Inspected the VDI configuration for a vendor or contractor and determined that it required both valid login credentials and MFA for successful vendor or contractor remote network access.	KPMG was unable to conclude on the design and operating effectiveness of the control prior to May 31, 2025 because observations could not be performed and evidence could not be provided prior to the transition. Subsequent to May 31, 2025, no exceptions noted.

Common Criteria 6.1

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-77	Encryption keys used to encrypt laptops are managed throughout the lifecycle (generation, use, storage, and destruction).	Inspected the configuration for a selection of Windows user laptops and determined that encryption keys were generated as part of the standard build requirements. Inspected the encryption configuration for Windows laptops and determined that encryption keys were used and stored on user laptops. Inspected a selection of Windows laptop hard drives tagged for decommissioning and determined that encryption keys were destroyed during the laptop decommissioning process.	No exceptions noted.

Common Criteria 6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-17	Windows AD access on the primary domain is disabled via an automated process on the day of termination.	Inspected the DT MIM configuration and determined that MIM was configured to disable AD accounts on the primary domain on the day of termination. Observed the DT Active Directory removal process and noted access was disabled on the day of termination.	No exceptions noted.
INF-34	An approval process is established to provision new privileged users with appropriate and required access to the authorized servers.	Inspected logical access documentation for a selection of new privileged users with access to servers and determined that access was approved by management and provisioned as requested.	No exceptions noted.
INF-50	Administrative access to servers is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of servers and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-56	Administrative access to firewalls is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for firewalls and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-57	Administrative access to routers and switches is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of routers and switches and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-95	Administrative access to the VPN is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the VPN and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-96	Administrative access to the primary domain is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the primary domain and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-55	Administrative access to Secret Server is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Secret Server Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-73	Administrative access to MAC is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the MAC Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-84	Administrative access to MIM is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the DT MIM Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-85	Administrative access to ServiceNow is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the ServiceNow Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-86	Administrative access to C-Cure is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the C-Cure Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-88	Administrative access to Omni and Compass is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Omni Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management. Inspected the administrator access listing for the Compass Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-90	Administrative access to Splunk is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Splunk Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-91	Administrative access to SolarWinds is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the SolarWinds Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-92	Administrative access to Dynatrace is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Dynatrace Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-58	MAC is configured to pull data completely and accurately from Windows Active Directory.	Inspected the MAC tool configuration and determined that the MAC tool was configured to pull data directly from Windows AD. Observed the generation of an AD group listing within the MAC tool and compared to the Windows AD Listing and determined that the MAC tool AD group listing was complete and accurate.	No exceptions noted.

Common Criteria 6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-87	MAC is configured to pull data completely and accurately from C-Cure.	Inspected the MAC tool configuration and determined that the MAC tool was configured to pull data directly from C-Cure. Observed the generation of a C-Cure access listing within the MAC tool and compared to the C-Cure system listing and determined that the MAC tool listing was complete and accurate.	No exceptions noted.
INF-89	Omni is configured to pull data completely and accurately from assets. Compass is configured to pull asset data completely and accurately from Omni for reporting purposes.	Inspected the Omni configuration and determined that Omni was configured to pull data completely and accurately from assets. Inspected the Compass configuration and determined that Compass was configured to pull data directly from Omni for reporting purposes. Inspected the in-scope Compass APIs and determined that APIs were in place to query asset data from Omni and generate complete and accurate reports.	No exceptions noted.
INF-40	The security policies require that user system access is removed upon termination of employment or job transfer where access is no longer required.	Inspected the access removal evidence and access listing for a selection of terminated or transferred server users and determined that the users were removed timely.	No exceptions noted.
INF-42	On a semiannual basis, a review of accounts in domain groups with privileged access is performed and documented. Any identified access issues are tracked and resolved in a timely manner.	Inspected the privileged access review and approval for accounts with privileged access for a selection of domain groups with privileged access and determined that the accounts had an associated approval from a periodic review and identified access issues were tracked and resolved in a timely manner.	No exceptions noted.

Common Criteria 6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-41	Standard service accounts that meet DLLP-specified criteria are preapproved. Any deviations require additional approvals from DT-US Cyber Security.	Inspected the request tickets for a selection of standard service accounts and determined that standard service accounts that met DLLP-specified criteria were preapproved. Inspected the request tickets for a selection of service accounts that required deviations and determined that additional approvals from DT-US Cyber Security were required.	No exceptions noted.
INF-75	Privileged access is managed by Secret Server wherein administrators receive randomly generated passwords for a maximum duration of 24 hours.	Observed an administrator gain privileged access via Secret Server and noted that the administrator received a randomly generated password. Inspected the configuration of Secret Server and determined that passwords were scheduled to expire within 24 hours.	No exceptions noted.
INF-94	Privileged access to servers is provisioned to elevated Active Directory accounts which are managed by Secret Server.	Inspected the privileged access listings for a selection of servers to determine whether privileged access is managed by Secret Server using elevated Active Directory accounts.	Privileged access for 18 of 395 users was not managed by Secret Server for 7 of 20 servers selected.
INF-78	In order to connect to DLLP systems for administrative activities, a user must authenticate through a VPN that requires MFA.	Observed an administrator complete the VPN connection process and noted that MFA was required. Inspected the VPN configuration and determined that a user must use MFA.	No exceptions noted.
INF-93	Failed MAC deprovisioning transactions are reviewed weekly, and action is taken to resolve the failed transactions timely.	Inspected the failed MAC deprovisioning transactions review for a selection of weeks and determined that a review was performed and action was taken to resolve failed transactions timely.	No exceptions noted.

Common Criteria 6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-17	Windows AD access on the primary domain is disabled via an automated process on the day of termination.	Inspected the DT MIM configuration and determined that MIM was configured to disable AD accounts on the primary domain on the day of termination. Observed the DT Active Directory removal process and noted access was disabled on the day of termination.	No exceptions noted.
INF-34	An approval process is established to provision new privileged users with appropriate and required access to the authorized servers.	Inspected logical access documentation for a selection of new privileged users with access to servers and determined that access was approved by management and provisioned as requested.	No exceptions noted.
INF-50	Administrative access to servers is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of servers and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-56	Administrative access to firewalls is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for firewalls and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-57	Administrative access to routers and switches is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of routers and switches and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-95	Administrative access to the VPN is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the VPN and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-96	Administrative access to the primary domain is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the primary domain and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-55	Administrative access to Secret Server is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Secret Server Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-73	Administrative access to MAC is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the MAC Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-84	Administrative access to MIM is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the DT MIM Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-85	Administrative access to ServiceNow is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the ServiceNow Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-86	Administrative access to C-Cure is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the C-Cure Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-88	Administrative access to Omni and Compass is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Omni Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management. Inspected the administrator access listing for the Compass Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-90	Administrative access to Splunk is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Splunk Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-91	Administrative access to SolarWinds is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the SolarWinds Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-92	Administrative access to Dynatrace is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Dynatrace Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-58	MAC is configured to pull data completely and accurately from Windows Active Directory.	Inspected the MAC tool configuration and determined that the MAC tool was configured to pull data directly from Windows AD. Observed the generation of an AD group listing within the MAC tool and compared to the Windows AD Listing and determined that the MAC tool AD group listing was complete and accurate.	No exceptions noted.

Common Criteria 6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-87	MAC is configured to pull data completely and accurately from C-Cure.	Inspected the MAC tool configuration and determined that the MAC tool was configured to pull data directly from C-Cure. Observed the generation of a C-Cure access listing within the MAC tool and compared to the C-Cure system listing and determined that the MAC tool listing was complete and accurate.	No exceptions noted.
INF-89	Omni is configured to pull data completely and accurately from assets. Compass is configured to pull asset data completely and accurately from Omni for reporting purposes.	Inspected the Omni configuration and determined that Omni was configured to pull data completely and accurately from assets. Inspected the Compass configuration and determined that Compass was configured to pull data directly from Omni for reporting purposes. Inspected the in-scope Compass APIs and determined that APIs were in place to query asset data from Omni and generate complete and accurate reports.	No exceptions noted.
INF-40	The security policies require that user system access is removed upon termination of employment or job transfer where access is no longer required.	Inspected the access removal evidence and access listing for a selection of terminated or transferred server users and determined that the users were removed timely.	No exceptions noted.
INF-41	Standard service accounts that meet DLLP-specified criteria are preapproved. Any deviations require additional approvals from DT-US Cyber Security.	Inspected the request tickets for a selection of standard service accounts and determined that standard service accounts that met DLLP-specified criteria were preapproved. Inspected the request tickets for a selection of service accounts that required deviations and determined that additional approvals from DT-US Cyber Security were required.	No exceptions noted.

Common Criteria 6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-42	On a semiannual basis, a review of accounts in domain groups with privileged access is performed and documented. Any identified access issues are tracked and resolved in a timely manner.	Inspected the privileged access review and approval for accounts with privileged access for a selection of domain groups with privileged access and determined that the accounts had an associated approval from a periodic review and identified access issues were tracked and resolved in a timely manner.	No exceptions noted.
INF-93	Failed MAC deprovisioning transactions are reviewed weekly, and action is taken to resolve the failed transactions timely.	Inspected the failed MAC deprovisioning transactions review for a selection of weeks and determined that a review was performed and action was taken to resolve failed transactions timely.	No exceptions noted.

Common Criteria 6.4

The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-66	Badge readers are installed to restrict physical access to the Hermitage Data Center, USI communication rooms, and USM communication rooms	Observed the Hermitage Data Center and noted that badge readers were installed to restrict physical access. Observed the USI communication rooms and noted that badge readers were installed to restrict physical access. Observed the USM communication rooms and noted that badge readers were installed to restrict physical access.	No exceptions noted.
INF-86	Administrative access to C-Cure is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the C-Cure Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-87	MAC is configured to pull data completely and accurately from C-Cure.	Inspected the MAC tool configuration and determined that the MAC tool was configured to pull data directly from C-Cure. Observed the generation of a C-Cure access listing within the MAC tool and compared to the C-Cure system listing and determined that the MAC tool listing was complete and accurate.	No exceptions noted.

Common Criteria 6.4

The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-52	A quarterly review of access to the Hermitage Data Center is performed by the Data Center Manager. A quarterly review of access to the USM communication rooms and USI communication rooms is performed by the Communication Room Manager.	Inspected the Hermitage Data Center access review for a selection of quarters and determined that the review was completed by the Data Center Manager and any modifications were performed timely. Inspected the USM communication room access review for a selection of quarters and determined that the review was completed by the Communication Room Manager and any modifications were performed timely. Inspected the USI communication rooms access review for a selection of quarters and determined that a review was completed by the Communication Room Manager and any modifications were performed timely.	No exceptions noted.
INF-68	Management approves access to the Hermitage Data Center, USI communication rooms, and USM communication rooms based on job function before access is granted.	Inspected the access request forms and physical access listing for a selection of users granted physical access to the in-scope locations and determined that access was approved by management before it was granted and the access granted was consistent with the access requests.	No exceptions noted.
INF-69	The security policies require that a user's physical access to the Hermitage Data Center, USI communication rooms, and USM communication rooms is removed within two days of termination of employment or job transfer where access is no longer required.	Inspected the termination request for a selection of terminated and transferred users and the Hermitage Data Center, USI communication rooms, and USM communication rooms user listings and determined that the user's access was removed within two days of termination or transfer.	No exceptions noted.

Common Criteria 6.4

The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-36	Visitor access to the Hermitage Data Center, USI communication rooms, and USM communication rooms is logged.	Inspected the visitor logs for the Hermitage Data Center for a selection of days and determined that the logs were maintained to record visitor access to the facilities. Inspected the visitor logs for the USI communication rooms for a selection of days and determined that the logs were maintained to record visitor access to the facilities. Inspected the visitor logs for the USM communication rooms for a selection of days and determined that the logs were maintained to record visitor access to the facilities.	No exceptions noted.
INF-70	Laptop hard drives are decommissioned by the DT-US organization. The laptops awaiting decommissioning are stored in a secure location. The laptops are then securely erased using industry-standard software. The decommissioning process is tracked and documented in ServiceNow.	Inspected the laptop procedure documents and determined that laptop hard drives were decommissioned via a documented process. Inspected a selection of laptop hard drives tagged for decommissioning and determined that they were decommissioned based on the documented process. Observed the Hermitage Data Center and noted that laptops awaiting decommissioning were stored in a secure location.	No exceptions noted.
INF-74	Servers awaiting decommissioning are stored in a secure room and the hard disk drives are securely erased using industry-standard software. The request, approval, and resulting actions are documented.	Inspected the server decommissioning procedures and determined that the process, including requests, approvals, and resulting actions, was documented. Inspected the ticket for a selection of decommissioned servers and determined that the request, approval, and resulting actions were documented. Observed the Hermitage Data Center and noted that servers awaiting decommissioning were stored in a secure room.	No exceptions noted.

Common Criteria 6.5

The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-29	Mobile devices must have the MDM software installed and be enrolled in the MDM solution in order to access the DLLP network. The MDM software encrypts the device, isolates, and protects DLLP data and applications, requires a PIN, enforces screen lockout after inactivity, enforces operating system updates, and remotely wipes the device after 8 incorrect PIN attempts or if the device is reported lost or stolen.	Inspected the mobile device configuration and determined the mobile devices had the MDM software installed, were encrypted, required a PIN, enforced screen lockout after inactivity, enforced operating system updates, and in the event of 8 incorrect PIN attempts, the device would be remotely wiped.	No exceptions noted.
Infrastructure			
INF-70	Laptop hard drives are decommissioned by the DT-US organization. The laptops awaiting decommissioning are stored in a secure location. The laptops are then securely erased using industry-standard software. The decommissioning process is tracked and documented in ServiceNow.	Inspected the laptop procedure documents and determined that laptop hard drives were decommissioned via a documented process. Inspected a selection of laptop hard drives tagged for decommissioning and determined that they were decommissioned based on the documented process. Observed the Hermitage Data Center and noted that laptops awaiting decommissioning were stored in a secure location.	No exceptions noted.
INF-74	Servers awaiting decommissioning are stored in a secure room and the hard disk drives are securely erased using industry-standard software. The request, approval, and resulting actions are documented.	Inspected the server decommissioning procedures and determined that the process, including requests, approvals, and resulting actions, was documented. Inspected the ticket for a selection of decommissioned servers and determined that the request, approval, and resulting actions were documented. Observed the Hermitage Data Center and noted that servers awaiting decommissioning were stored in a secure room.	No exceptions noted.

Common Criteria 6.5

The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-76	Media assets (laptops or hard drives) that are unable to be wiped by DLLP are sent to a third party for destruction. DLLP tracks and stores the destruction report as proof that the media asset was destroyed.	Inspected the DT-US Teams directory and the destruction report received from the third party for a selection of destruction jobs containing media assets unable to be wiped by DLLP that were identified for destruction and determined that DLLP tracked that the media assets were destroyed.	No exceptions noted.

Common Criteria 6.6

The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-29	Mobile devices must have the MDM software installed and be enrolled in the MDM solution in order to access the DLLP network. The MDM software encrypts the device, isolates, and protects DLLP data and applications, requires a PIN, enforces screen lockout after inactivity, enforces operating system updates, and remotely wipes the device after 8 incorrect PIN attempts or if the device is reported lost or stolen.	Inspected the mobile device configuration and determined the mobile devices had the MDM software installed, were encrypted, required a PIN, enforced screen lockout after inactivity, enforced operating system updates, and in the event of 8 incorrect PIN attempts, the device would be remotely wiped.	No exceptions noted.
Infrastructure			
INF-35	In order for a professional to obtain remote network access, the connecting laptop must: • Be a recognized DLLP laptop. • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Observed a DLLP professional complete the VPN connection process and noted that it required a DLLP laptop and a valid user ID and password within AD for successful remote network access. Observed a DLLP professional attempt to login to the DLLP network without completing the VPN connection process and noted that the professional was unsuccessful. Inspected the VPN configuration for a DLLP professional and determined that it required both valid login credentials, a DLLP laptop, and MFA for successful professional remote network access.	No exceptions noted.

Common Criteria 6.6

The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-45	Prior to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Pass a security scan. • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application. Subsequent to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Be connected to a DLLP configured VDI • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Inquired of management and were informed that the process for vendors and contractors to obtain remote network access changed on May 31, 2025. Subsequent to May 31, 2025: Observed a vendor or contractor complete the VDI connection process on their laptop and noted that it required both valid login credentials and MFA for successful vendor/contractor remote network access. Observed a vendor or contractor attempt to login to the DLLP network on their laptop without completing the VDI connection process and noted that the vendor/contractor was unsuccessful. Inspected the VDI configuration for a vendor or contractor and determined that it required both valid login credentials and MFA for successful vendor or contractor remote network access.	KPMG was unable to conclude on the design and operating effectiveness of the control prior to May 31, 2025 because observations could not be performed and evidence could not be provided prior to the transition. Subsequent to May 31, 2025, no exceptions noted.
INF-38	Firewalls with IPS components are in place on the network and are updated for the latest rule set on a regular basis (at least weekly).	Inspected the IPS configuration for a selection of firewalls with IPS components applied and determined that the selected devices were updated to the latest rule set on a regular basis (at least weekly).	No exceptions noted.

Common Criteria 6.6

The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-39	Firewalls are in place to prevent unauthorized access to the DLLP network. New firewall rules or changes to existing firewall rules are approved before they are implemented.	Inspected the firewall console for a selection of firewalls and determined that firewalls were in place to prevent unauthorized access to the DLLP network. Inspected a selection of new firewall rules or changes to existing firewall rules and determined that new firewall rules or changes to existing firewall rules were approved before they were implemented.	No exceptions noted.
INF-47	Unattended laptops are locked using a screensaver that requires a password to unlock.	Inspected the configuration for a selection of laptops and determined that a screensaver was enabled and a password was required to unlock the device.	No exceptions noted.
INF-46	Anti-virus and anti-malware solutions are installed on servers.	Inspected the anti-virus and anti-malware agent documentation for a selection of servers and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-43	Anti-virus and anti-malware solutions are installed on laptops.	Inspected the anti-virus and anti-malware agent documentation for a selection of laptops and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-37	Password settings are implemented on each system and require a minimum length of 10 characters, password complexity, an expiration of no longer than 90 days, a history of 24 passwords remembered, and lockout after five invalid attempts.	Inspected the domain password security settings and password security settings for a selection of servers and determined that the policy required a history of 24 passwords remembered, minimum password length of 10 characters, a complex password, password expiration no longer than 90 days, and password lockout after five invalid attempts.	No exceptions noted.

Common Criteria 6.6

The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.
INF-48	Authentication credentials transmitted to network devices are encrypted in transit.	Inspected the configuration for a selection of network devices and determined that encryption methods were enabled for authentication credentials during transit.	No exceptions noted.

Common Criteria 6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-29	Mobile devices must have the MDM software installed and be enrolled in the MDM solution in order to access the DLLP network. The MDM software encrypts the device, isolates, and protects DLLP data and applications, requires a PIN, enforces screen lockout after inactivity, enforces operating system updates, and remotely wipes the device after 8 incorrect PIN attempts or if the device is reported lost or stolen.	Inspected the mobile device configuration and determined the mobile devices had the MDM software installed, were encrypted, required a PIN, enforced screen lockout after inactivity, enforced operating system updates, and in the event of 8 incorrect PIN attempts, the device would be remotely wiped.	No exceptions noted.
Infrastructure			
INF-48	Authentication credentials transmitted to network devices are encrypted in transit.	Inspected the configuration for a selection of network devices and determined that encryption methods were enabled for authentication credentials during transit.	No exceptions noted.
INF-49	A standard build is used for professional's laptops that includes: software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches.	Inspected the standard build template for Windows 10 laptops and determined that the standard build included application of a software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches. Inspected the configuration for a selection of user laptops and determined that the laptops were configured in line with the standard build requirements.	No exceptions noted.

Common Criteria 6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-80	A standard build is used for servers that includes: anti-virus software, a vulnerability scanning tool, passwords, a software distribution tool to apply the most recent approved operating system patches, and restriction of the ability to install and modify operating system and other system programs to authorized professionals.	Inspected the standard build for Windows and Linux servers and determined that the standard build included anti-virus software, a vulnerability scanning tool, passwords, a software distribution tool to apply the most recent approved operating system patches and the ability to install and modify operating system and other system programs to authorized professionals. Inspected the anti-virus agent, vulnerability scan agent, password settings, software distribution tool, and administrative user listings for a selection of servers and determined that the servers were configured in line with the standard build requirements.	No exceptions noted.
INF-83	Laptops are configured to block removable media.	Inspected the laptop configuration and determined that laptops were configured to block removable media.	No exceptions noted.
INF-77	Encryption keys used to encrypt laptops are managed throughout the lifecycle (generation, use, storage, and destruction).	Inspected the configuration for a selection of Windows user laptops and determined that encryption keys were generated as part of the standard build requirements. Inspected the encryption configuration for Windows laptops and determined that encryption keys were used and stored on user laptops. Inspected a selection of Windows laptop hard drives tagged for decommissioning and determined that encryption keys were destroyed during the laptop decommissioning process.	No exceptions noted.

Common Criteria 6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-74	Servers awaiting decommissioning are stored in a secure room and the hard disk drives are securely erased using industry-standard software. The request, approval, and resulting actions are documented.	Inspected the server decommissioning procedures and determined that the process, including requests, approvals, and resulting actions, was documented. Inspected the ticket for a selection of decommissioned servers and determined that the request, approval, and resulting actions were documented. Observed the Hermitage Data Center and noted that servers awaiting decommissioning were stored in a secure room.	No exceptions noted.
INF-70	Laptop hard drives are decommissioned by the DT-US organization. The laptops awaiting decommissioning are stored in a secure location. The laptops are then securely erased using industry-standard software. The decommissioning process is tracked and documented in ServiceNow.	Inspected the laptop procedure documents and determined that laptop hard drives were decommissioned via a documented process. Inspected a selection of laptop hard drives tagged for decommissioning and determined that they were decommissioned based on the documented process. Observed the Hermitage Data Center and noted that laptops awaiting decommissioning are stored in a secure location.	No exceptions noted.
INF-76	Media assets (laptops or hard drives) that are unable to be wiped by DLLP are sent to a third party for destruction. DLLP tracks and stores the destruction report as proof that the media asset was destroyed.	Inspected the DT-US Teams directory and the destruction report received from the third party for a selection of destruction jobs containing media assets unable to be wiped by DLLP that were identified for destruction and determined that DLLP tracked that the media assets were destroyed.	No exceptions noted.

Common Criteria 6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-35	In order for a professional to obtain remote network access, the connecting laptop must: Be a recognized DLLP laptop. Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Observed a DLLP professional complete the VPN connection process and noted that it required a DLLP laptop and a valid user ID and password within AD for successful remote network access. Observed a DLLP professional attempt to login to the DLLP network without completing the VPN connection process and noted that the professional was unsuccessful. Inspected the VPN configuration for a DLLP professional and determined that it required both valid login credentials, a DLLP laptop, and MFA for successful professional remote network access.	No exceptions noted.

Common Criteria 6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-45	Prior to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Pass a security scan. • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application. Subsequent to May 31, 2025, in order for a vendor or contractor to obtain remote network access, the connecting laptop must: • Be connected to a DLLP configured VDI • Authenticate using MFA with a valid user ID that belongs to DLLP's AD, as well as a password, and enter a code that the user receives from a text message or a mobile application.	Inquired of management and were informed that the process for vendors and contractors to obtain remote network access changed on May 31, 2025. Subsequent to May 31, 2025: Observed a vendor or contractor complete the VDI connection process on their laptop and noted that it required both valid login credentials and MFA for successful vendor/contractor remote network access. Observed a vendor or contractor attempt to login to the DLLP network on their laptop without completing the VDI connection process and noted that the vendor/contractor was unsuccessful. Inspected the VDI configuration for a vendor or contractor and determined that it required both valid login credentials and MFA for successful vendor or contractor remote network access.	KPMG was unable to conclude on the design and operating effectiveness of the control prior to May 31, 2025 because observations could not be performed and evidence could not be provided prior to the transition. Subsequent to May 31, 2025, no exceptions noted.

Common Criteria 6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-18	A change request process is in place for system tools and change requests are documented, tested, and approved prior to implementation.	Inspected the system tools' version history and the associated change ticket for a selection of system tools and determined that changes to the tool were tracked in a change ticket. Inspected the change ticket and other documentation for a selection of system tool changes and determined that the changes were documented, tested, and approved prior to implementation into the production environment.	No exceptions noted.
INF-14	A change request process is in place for system tools, and emergency change requests are documented, tested, and approved according to the change request process.	Inspected the change documentation for a selection of emergency system tool changes and determined that the changes were documented, tested, and approved according to the change request process.	No exceptions noted.
INF-50	Administrative access to servers is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of servers and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-56	Administrative access to firewalls is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for firewalls and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-57	Administrative access to routers and switches is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of routers and switches and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-95	Administrative access to the VPN is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the VPN and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-96	Administrative access to the primary domain is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the primary domain and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-55	Administrative access to Secret Server is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Secret Server Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-73	Administrative access to MAC is restricted to authorized professionals according to job responsibilities.	Inspected the user access listing for the MAC Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-84	Administrative access to MIM is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the DT MIM Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-85	Administrative access to ServiceNow is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the ServiceNow Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-86	Administrative access to C-Cure is restricted to authorized professionals according to job responsibilities.	Inspected the user access listing for the C-Cure Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-88	Administrative access to Omni and Compass is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Omni Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management. Inspected the administrator access listing for the Compass Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-90	Administrative access to Splunk is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Splunk Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-91	Administrative access to SolarWinds is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the SolarWinds Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-92	Administrative access to Dynatrace is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Dynatrace Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-81	The ability to install, modify, and replace operating system and other system programs is restricted to authorized professionals.	Inspected the access listing for a selection of servers and determined that access was restricted to authorized individuals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-44	End users are restricted from installing prohibited software on laptops.	Inspected the Electronic Communications and Systems policy and determined that the policy defined the restrictions for end user installation of prohibited software on laptops. Inspected the Software Distribution (SCCM) configuration for a selection of laptops and determined that end users were restricted from installing prohibited software on laptops.	No exceptions noted.
INF-53	Server patches are tested and approved prior to implementation to a production server and are applied within three months of issue by the vendor.	Inspected the patch management policy and determined that the policy defined the patch installation process. Inspected the vendor website, patch log, and change ticket for a selection of servers and months to determine whether server patches were tested, approved, and applied within three months of issue by the vendor.	Patches were not applied within three months of issue by vendor for 2 of 3 months selected for 1 of 19 selected servers.
INF-46	Anti-virus and anti-malware solutions are installed on servers.	Inspected the anti-virus and anti-malware agent documentation for a selection of servers and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-43	Anti-virus and anti-malware solutions are installed on laptops.	Inspected the anti-virus and anti-malware agent documentation for a selection of laptops and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-39	Firewalls are in place to prevent unauthorized access to the DLLP network. New firewall rules or changes to existing firewall rules are approved before they are implemented.	Inspected the firewall console for a selection of firewalls and determined that firewalls were in place to prevent unauthorized access to the DLLP network. Inspected a selection of new firewall rules or changes to existing firewall rules and determined that new firewall rules or changes to existing firewall rules were approved before they were implemented.	No exceptions noted.

Common Criteria 6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.

7.0 SYSTEM OPERATIONS

Common Criteria 7.1 To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.
INF-46	Anti-virus and anti-malware solutions are installed on servers.	Inspected the anti-virus and anti-malware agent documentation for a selection of servers and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-43	Anti-virus and anti-malware solutions are installed on laptops.	Inspected the anti-virus and anti-malware agent documentation for a selection of laptops and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.

Common Criteria 7.1

To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-59	Critical infrastructure components (e.g., network availability, servers, network devices) are monitored for availability on an ongoing basis through automated alerting and corrective action is implemented in a timely manner when necessary.	Inspected the availability monitoring agent documentation for a selection of servers and network devices and determined that the monitoring agent was present. Inspected the details and configuration for a selection of monitoring alert rules and determined that alert rules were in place and configured to monitor critical infrastructure components (e.g., network availability, servers, network devices) for availability. Inspected the corresponding ticket for a selection of availability alerts and determined that corrective action was implemented in a timely manner.	No exceptions noted.
INF-28	Vulnerability scans are conducted monthly on internal networks and the external perimeter to detect vulnerabilities. The detected vulnerabilities are reviewed, and remediation or risk acceptance is completed timely.	Inspected Qualys AssetView and for a selection of devices and determined that the devices were running on Qualys. Inspected the internal vulnerability scans for a selection of months and devices and determined that the detected vulnerabilities were remediated, or risk accepted in a timely manner. Inspected the external vulnerability scans for a selection of months and devices and determined that detected vulnerabilities were remediated or risk accepted in a timely manner.	No exceptions noted.
INF-29	A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.	Inspected the Vulnerability Management Service presentation and the included vulnerability scan summary for a selection of months and determined that a summary of vulnerabilities was reported to Executive management monthly.	No exceptions noted.

Common Criteria 7.1

To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-24	Secure system configuration standards are defined and reviewed and approved annually for each type of server, laptop operating system, and network device within the system.	Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were defined. Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were reviewed and approved annually.	No exceptions noted.

Common Criteria 7.2

The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed and determined that they represent security events.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-46	Anti-virus and anti-malware solutions are installed on servers.	Inspected the anti-virus and anti-malware agent documentation for a selection of servers and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-43	Anti-virus and anti-malware solutions are installed on laptops.	Inspected the anti-virus and anti-malware agent documentation for a selection of laptops and determined that anti-virus and anti-malware solutions were installed.	No exceptions noted.
INF-54	For high-severity security and availability incidents, a root cause analysis is conducted and discussed with Risk Management. Based on the root cause analysis, change requests are prepared and the Risk Management process and relevant risk management data are updated to reflect the planned incident and problem resolution.	Inquired of management and was informed that there were no high-severity security and availability incidents during the period that required a root cause analysis. Inspected ServiceNow for incidents created and assigned to the Cyber Security DLLP Incident Response team and determined that there were no high-severity security and availability incidents.	There were no high-severity security and availability incidents that occurred during the examination period. KPMG was unable to test the operating effectiveness of the control because the circumstances that warrant the operation of the control did not occur during the examination period. .
INF-15	An information security incident management policy is maintained, reviewed, and approved every 12 months. A revision history is also maintained. The policy includes organization structure, response procedures, and timelines for incident resolution and the communication of incidents (including operational impact, timeline, and cost), and requires that changes to the system follow the established change management policy.	Inspected the Information Security Incident Management policy and determined that it covered the policy requirements set forth by the security category and it required that changes to the system follow the established change management policy. Furthermore, determined that the policy was maintained, reviewed, and approved in the past 12 months.	No exceptions noted.

Common Criteria 7.2

The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed and determined that they represent security events.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-67	Security incidents are documented and corrective action is implemented in a timely manner when necessary	Inspected the incident ticket for a selection of incidents and determined that the incident was documented and corrective action was implemented in a timely manner when necessary.	No exceptions noted.
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.
INF-28	Vulnerability scans are conducted monthly on internal networks and the external perimeter to detect vulnerabilities. The detected vulnerabilities are reviewed, and remediation or risk acceptance is completed timely.	Inspected Qualys AssetView for a selection of devices and determined that the devices were running on Qualys. Inspected the internal vulnerability scans for a selection of months and devices and determined that the detected vulnerabilities were remediated, or risk accepted in a timely manner. Inspected the external vulnerability scans for a selection of months and devices and determined that detected vulnerabilities were remediated or risk accepted in a timely manner.	No exceptions noted.
INF-29	A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.	Inspected the Vulnerability Management Service presentation and the included vulnerability scan summary for a selection of months and determined that a summary of vulnerabilities was reported to Executive management monthly.	No exceptions noted.

Common Criteria 7.2

The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed and determined that they represent security events.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-59	Critical infrastructure components (e.g., network availability, servers, network devices) are monitored for availability on an ongoing basis through automated alerting and corrective action is implemented in a timely manner when necessary.	Inspected the availability monitoring agent documentation for a selection of servers and network devices and determined that the monitoring agent was present. Inspected the details and configuration for a selection of monitoring alert rules and determined that alert rules were in place and configured to monitor critical infrastructure components (e.g., network availability, servers, network devices) for availability. Inspected the corresponding ticket for a selection of availability alerts and determined that corrective action was implemented in a timely manner.	No exceptions noted.

Common Criteria 7.3

The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-15	An information security incident management policy is maintained, reviewed, and approved every 12 months. A revision history is also maintained. The policy includes organization structure, response procedures, and timelines for incident resolution and the communication of incidents (including operational impact, timeline, and cost) and requires that changes to the system follow the established change management policy.	Inspected the Information Security Incident Management policy and determined that it covered the policy requirements set forth by the security category and it required that changes to the system follow the established change management policy. Furthermore, determined that the policy was maintained, reviewed, and approved in the past 12 months.	No exceptions noted.
INF-54	For high-severity security and availability incidents, a root cause analysis is conducted and discussed with Risk Management. Based on the root cause analysis, change requests are prepared and the Risk Management process and relevant risk management data are updated to reflect the planned incident and problem resolution.	Inquired of management and was informed that there were no high-severity security and availability incidents during the period that required a root cause analysis. Inspected ServiceNow for incidents created and assigned to the Cyber Security DLLP Incident Response team and determined that there were no high-severity security and availability incidents.	There were no high-severity security and availability incidents that occurred during the examination period. KPMG was unable to test the operating effectiveness of the control because the circumstances that warrant the operation of the control did not occur during the examination period. .
INF-67	Security incidents are documented and corrective action is implemented in a timely manner when necessary	Inspected the incident ticket, for a selection of incidents, and determined that the incident was documented and corrective action was implemented in a timely manner when necessary.	No exceptions noted.

Common Criteria 7.3

The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.
INF-28	Vulnerability scans are conducted monthly on internal networks and the external perimeter to detect vulnerabilities. The detected vulnerabilities are reviewed, and remediation or risk acceptance is completed timely.	Inspected Qualys AssetView for a selection of devices and determined that the devices were running on Qualys. Inspected the internal vulnerability scans for a selection of months and devices and determined that the detected vulnerabilities were remediated, or risk accepted in a timely manner. Inspected the external vulnerability scans for a selection of months and devices and determined that detected vulnerabilities were remediated or risk accepted in a timely manner.	No exceptions noted.
INF-29	A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.	Inspected the Vulnerability Management Service presentation and the included vulnerability scan summary for a selection of months and determined that a summary of vulnerabilities was reported to Executive management monthly.	No exceptions noted.

Common Criteria 7.3

The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-49	A standard build is used for professional's laptops that includes: software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches.	Inspected the standard build template for Windows 10 laptops and determined that the standard build included application of a software firewall, anti-virus software, anti-spyware software, encryption software, backup software, DLP software, and a software distribution tool to apply the most recent approved operating system patches. Inspected the configuration for a selection of user laptops and determined that the laptops were configured in line with the standard build requirements.	No exceptions noted.

Common Criteria 7.4

The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-13	DLLP communicates its objectives related to security, availability, and changes to objectives (i.e., technology changes, leadership changes, and policy changes) through various channels such as posts on DLLP's intranet site or email.	Observed DLLP's intranet site and noted that DLLP communicated its objectives and changes to objectives through posting on DLLP's intranet site. Inspected DLLP's intranet site and/or an email for a selection of changes to objectives and determined that DLLP communicated changes to objectives.	No exceptions noted.
Infrastructure			
INF-2	The CISO is responsible for security, including the design, development, implementation, operation, maintenance, monitoring, and approval of the entity's system controls and other risk mitigation strategies for the system. The Cyber Security Strategy leader, Security Operations leader, and Risk and Compliance leader report to the CISO. The organizational chart is reviewed by DT-US Business Operations on an annual basis.	Inspected the organizational charts and determined that the teams responsible for security were reviewed and updated on an annual basis (within the past 12 months) and determined that the Cyber Security Strategy leader, Security Operations leader, and Risk and Compliance leader reported to the CISO.	No exceptions noted.
INF-4	The T&I organization, under the CTO, is responsible for availability, including the design, development, implementation, operation, maintenance, monitoring, and approval of the entity's system controls and other risk mitigation strategies for the system. The organizational charts are reviewed by DT-US Business Operations on an annual basis.	Inspected the DLLP Organizational Chart and determined that the organizational chart was reviewed within the year and the T&I organization was responsible for availability, including the design, development, implementation, operation, maintenance, monitoring and approval of the entity's system controls and other risk mitigation strategies for the system.	No exceptions noted.

Common Criteria 7.4

The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-15	An information security incident management policy is maintained, reviewed, and approved every 12 months. A revision history is also maintained. The policy includes organization structure, response procedures, and timelines for incident resolution and the communication of incidents (including operational impact, timeline, and cost) and requires that changes to the system follow the established change management policy.	Inspected the Information Security Incident Management policy and determined that it covered the policy requirements set forth by the security category and it required that changes to the system follow the established change management policy. Furthermore, determined that the policy was maintained, reviewed, and approved in the past 12 months.	No exceptions noted.
INF-54	For high-severity security and availability incidents, a root cause analysis is conducted and discussed with Risk Management. Based on the root cause analysis, change requests are prepared and the Risk Management process and relevant risk management data are updated to reflect the planned incident and problem resolution.	Inquired of management and was informed that there were no high-severity security and availability incidents during the period that required a root cause analysis. Inspected ServiceNow for incidents created and assigned to the Cyber Security DLLP Incident Response team and determined that there were no high-severity security and availability incidents.	There were no high-severity security and availability incidents that occurred during the examination period. KPMG was unable to test the operating effectiveness of the control because the circumstances that warrant the operation of the control did not occur during the examination period. .
INF-67	Security incidents are documented and corrective action is implemented in a timely manner when necessary	Inspected the incident ticket, for a selection of incidents, and determined that the incident was documented and corrective action was implemented in a timely manner when necessary.	No exceptions noted.

Common Criteria 7.4

The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-28	Vulnerability scans are conducted monthly on internal networks and the external perimeter to detect vulnerabilities. The detected vulnerabilities are reviewed, and remediation or risk acceptance is completed timely.	Inspected Qualys AssetView for a selection of devices and determined that the devices were running on Qualys. Inspected the internal vulnerability scans for a selection of months and devices and determined that the detected vulnerabilities were remediated, or risk accepted in a timely manner. Inspected the external vulnerability scans for a selection of months and devices and determined that detected vulnerabilities were remediated or risk accepted in a timely manner.	No exceptions noted.
INF-29	A summary of monthly vulnerabilities is presented to Executive Management during the Monthly Global & US Cybersecurity Briefing.	Inspected the Vulnerability Management Service presentation and the included vulnerability scan summary for a selection of months and determined that a summary of vulnerabilities was reported to Executive management monthly.	No exceptions noted.
INF-22	A DR plan, including dependencies, maximum allowable downtime, and response plans, is approved annually, implemented, and maintained.	Inspected the DR plan and determined that the plan contained dependencies, maximum allowable downtime, and response plans, and was approved and updated annually.	No exceptions noted.
INF-38	Firewalls with IPS components are in place on the network and are updated for the latest rule set on a regular basis (at least weekly).	Inspected the IPS configuration for a selection of firewalls with IPS components applied and determined that the selected devices were updated to the latest rule set on a regular basis (at least weekly).	No exceptions noted.

Common Criteria 7.4

The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.
INF-19	Changes that affect system user responsibilities or DLLP's commitments and requirements relevant to security and availability are communicated to impacted users and alerts are posted to DLLP's intranet site.	Inspected a selection of email notifications distributed by Technology Services to users and DLLP's intranet site and determined that changes or issues that impact the system were communicated.	No exceptions noted.

Common Criteria 7.5

The entity identifies, develops, and implements activities to recover from identified security incidents.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-33	DLLP annually performs a "war games" tabletop exercise where top threat scenarios are selected and senior leadership executes the BCP to practice for scenarios that could impair DLLP's ability to recover from various incidents.	Inspected the "war games" documentation and determined that the tabletop exercise was performed. Inspected the "war games" meeting invite and determined that the "war games" results were communicated to the CISO and CTO.	No exceptions noted.
Infrastructure			
INF-59	Critical infrastructure components (e.g., network availability, servers, network devices) are monitored for availability on an ongoing basis through automated alerting and corrective action is implemented in a timely manner when necessary.	Inspected the availability monitoring agent documentation for a selection of servers and network devices and determined that the monitoring agent was present. Inspected the details and configuration for a selection of monitoring alert rules and determined that alert rules were in place and configured to monitor critical infrastructure components (e.g., network availability, servers, network devices) for availability. Inspected the corresponding ticket for a selection of availability alerts and determined that corrective action was implemented in a timely manner.	No exceptions noted.
INF-22	A DR plan, including dependencies, maximum allowable downtime, and response plans, is approved annually, implemented, and maintained.	Inspected the DR plan and determined that the plan contained dependencies, maximum allowable downtime, and response plans, and was approved and updated annually.	No exceptions noted.
INF-65	Business continuity test plans for DLLP Managed IT services are scoped and the problems identified are documented with an associated remediation action. The critical BCP or DR plans are tested on an annual basis.	Inspected a selection of business continuity and DR test plans and determined that DLLP Managed IT services were scoped, the problems identified were documented with an associated remediation action, and testing was performed on an annual basis.	No exceptions noted.

Common Criteria 7.5

The entity identifies, develops, and implements activities to recover from identified security incidents.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-15	An information security incident management policy is maintained, reviewed, and approved every 12 months. A revision history is also maintained. The policy includes organization structure, response procedures, and timelines for incident resolution and the communication of incidents (including operational impact, timeline, and cost) and requires that changes to the system follow the established change management policy.	Inspected the Information Security Incident Management policy and determined that it covered the policy requirements set forth by the security category and it required that changes to the system follow the established change management policy. Furthermore, determined that the policy was maintained, reviewed, and approved in the past 12 months.	No exceptions noted.
INF-54	For high-severity security and availability incidents, a root cause analysis is conducted and discussed with Risk Management. Based on the root cause analysis, change requests are prepared and the Risk Management process and relevant risk management data are updated to reflect the planned incident and problem resolution.	Inquired of management and was informed that there were no high-severity security and availability incidents during the period that required a root cause analysis. Inspected ServiceNow for incidents created and assigned to the Cyber Security DLLP Incident Response team and determined that there were no high-severity security and availability incidents.	There were no high-severity security and availability incidents that occurred during the examination period. KPMG was unable to test the operating effectiveness of the control because the circumstances that warrant the operation of the control did not occur during the examination period.
INF-67	Security incidents are documented and corrective action is implemented in a timely manner when necessary	Inspected the incident ticket, for a selection of incidents, and determined that the incident was documented and corrective action was implemented in a timely manner when necessary.	No exceptions noted.

Common Criteria 7.5

The entity identifies, develops, and implements activities to recover from identified security incidents.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-51	Security alerts are monitored by the Security Operations Center, logged in ServiceNow, and tracked to resolution.	Inspected the Control Panel for a selection of servers and determined that the Splunk Forwarding Agent was installed. Inspected the Splunk configuration for a selection of security monitoring rules and determined that Splunk was configured to automatically send alerts to ServiceNow, creating a ServiceNow ticket. Inspected the ServiceNow tickets for a selection of security alerts and determined that the alert was tracked to appropriate resolution.	No exceptions noted.

8.0 CHANGE MANAGEMENT

Common Criteria 8.1 The entity authorizes, designs, develops, or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-18	A change request process is in place for system tools and change requests are documented, tested, and approved prior to implementation.	Inspected the system tools' version history and the associated change ticket for a selection of system tools and determined that changes to the tool were tracked in a change ticket. Inspected the change ticket and other documentation for a selection of system tool changes and determined that the changes were documented, tested, and approved prior to implementation into the production environment.	No exceptions noted.
INF-14	A change request process is in place for system tools, and emergency change requests are documented, tested, and approved according to the change request process.	Inspected the change documentation for a selection of emergency system tool changes and determined that the changes were documented, tested, and approved according to the change request process.	No exceptions noted.
INF-81	The ability to install, modify, and replace operating system and other system programs is restricted to authorized professionals.	Inspected the access listing for a selection of servers and determined that access was restricted to authorized individuals based on job title and inquiry with management.	No exceptions noted.
INF-44	End users are restricted from installing prohibited software on laptops.	Inspected the Electronic Communications and Systems policy and determined that the policy defined the restrictions for end user installation of prohibited software on laptops. Inspected the Software Distribution (SCCM) configuration for a selection of laptops and determined that end users were restricted from installing prohibited software on laptops.	No exceptions noted.

Common Criteria 8.1

The entity authorizes, designs, develops, or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-24	Secure system configuration standards are defined and reviewed and approved annually for each type of server, laptop operating system, and network device within the system.	Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were defined. Inspected the system configuration standard for each type of server, laptop operating system, and network device within the system and determined that the configuration standards were reviewed and approved annually.	No exceptions noted.
INF-53	Server patches are tested and approved prior to implementation to a production server and are applied within three months of issue by the vendor.	Inspected the patch management policy and determined that the policy defined the patch installation process. Inspected the vendor website, patch log, and change ticket for a selection of servers and months to determine whether server patches were tested, approved, and applied within three months of issue by the vendor.	Patches were not applied within three months of issue by vendor for 2 of 3 months selected for 1 of 19 selected servers.
INF-50	Administrative access to servers is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of servers and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-56	Administrative access to firewalls is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for firewalls and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-57	Administrative access to routers and switches is restricted to authorized professionals according to job responsibilities.	Inspected administrator access listings for a selection of routers and switches and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 8.1

The entity authorizes, designs, develops, or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-95	Administrative access to the VPN is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the VPN and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-96	Administrative access to the primary domain is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the primary domain and an HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-55	Administrative access to Secret Server is restricted to authorized professionals according to job responsibilities.	Inspected the user access listing for the Secret Server Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-73	Administrative access to MAC is restricted to authorized professionals according to job responsibilities.	Inspected the user access listing for the MAC Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-84	Administrative access to MIM is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the DT MIM Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-86	Administrative access to C-Cure is restricted to authorized professionals according to job responsibilities.	Inspected the user access listing for the C-Cure Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.

Common Criteria 8.1

The entity authorizes, designs, develops, or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-88	Administrative access to Omni and Compass is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Omni Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management. Inspected the administrator access listing for the Compass Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-90	Administrative access to Splunk is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Splunk Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-91	Administrative access to SolarWinds is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the SolarWinds Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-92	Administrative access to Dynatrace is restricted to authorized professionals according to job responsibilities.	Inspected the administrator access listing for the Dynatrace Tool and compared to the HR listing and determined that access was restricted to authorized professionals based on job title and inquiry with management.	No exceptions noted.
INF-39	Firewalls are in place to prevent unauthorized access to the DLLP network. New firewall rules or changes to existing firewall rules are approved before they are implemented.	Inspected the firewall console for a selection of firewalls and determined that firewalls were in place to prevent unauthorized access to the DLLP network. Inspected a selection of new firewall rules or changes to existing firewall rules and determined that new firewall rules or changes to existing firewall rules were approved before they were implemented.	No exceptions noted.

9.0 RISK MITIGATION

Common Criteria 9.1 The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.			
#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-31	DLLP maintains both first-party protection insurance and professional indemnity insurance to offset the financial impact of loss events that would otherwise impair their ability to meet their objectives.	Inspected the first-party protection insurance and professional indemnity Insurance policy documents and determined that they were maintained by DLLP.	No exceptions noted.
Infrastructure			
INF-65	Business continuity test plans for DLLP Managed IT services are scoped and the problems identified are documented with an associated remediation action. The critical BCP or DR plans are tested on an annual basis.	Inspected a selection of business continuity and DR test plans and determined that DLLP Managed IT services were scoped, the problems identified were documented with an associated remediation action, and testing was performed on an annual basis.	No exceptions noted.
INF-22	A DR plan, including dependencies, maximum allowable downtime, and response plans, is approved annually, implemented, and maintained.	Inspected the DR plan and determined that the plan contained dependencies, maximum allowable downtime, and response plans, and was approved and updated annually.	No exceptions noted.
INF-15	An information security incident management policy is maintained, reviewed, and approved every 12 months. A revision history is also maintained. The policy includes organization structure, response procedures, and timelines for incident resolution and the communication of incidents (including operational impact, timeline, and cost), and requires that changes to the system follow the established change management policy.	Inspected the Information Security Incident Management policy and determined that it covered the policy requirements set forth by the security category and it required that changes to the system follow the established change management policy. Furthermore, determined that the policy was maintained, reviewed, and approved in the past 12 months.	No exceptions noted.

Common Criteria 9.2

The entity assesses and manages risks associated with vendors and business partners.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Entity Level			
DEL-9	DLLP has established and assigned responsibility and accountability for the management of vendor/third-party risks. The Third-Party Security team performs third-party security assessments and re-assessments for contracted vendors are performed based on risk rating.	Inspected the latest third-party security assessment or re-assessment for a selection of vendors and determined that the Third-Party Security team was responsible for completing the assessment, and the assessment was completed based on risk rating.	No exceptions noted.
DEL-24	Standard contract templates, including service levels and compliance, privacy, and confidentiality requirements, are used for third-party vendors as necessary based on the service provided and deviations from those are reviewed and approved by key stakeholders.	Inspected the standard contract template for third-party vendors and determined that a template was in place for third-party vendors, as necessary based on the service provided, and included service levels and compliance, privacy, and confidentiality requirements. Inspected the contract for a selection of third-party vendors and determined that deviations from the contract template were reviewed and approved by key stakeholders.	No exceptions noted.

AVAILABILITY

Availability 1.1

The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-59	Critical infrastructure components (e.g., network availability, servers, network devices) are monitored for availability on an ongoing basis through automated alerting and corrective action is implemented in a timely manner when necessary.	Inspected the availability monitoring agent documentation for a selection of servers and network devices and determined that the monitoring agent was present. Inspected the details and configuration for a selection of monitoring alert rules and determined that alert rules were in place and configured to monitor critical infrastructure components (e.g., network availability, servers, network devices) for availability. Inspected the corresponding ticket for a selection of availability alerts and determined that corrective action was implemented in a timely manner.	No exceptions noted.
INF-60	Future processing demand is forecasted and compared to scheduled capacity on an ongoing basis. A T&I Senior Manager reviews and approves the forecasts on a monthly basis as part of the budgeting processes.	Inspected the forecast review by a T&I Senior Manager for a selection of months and determined that the future processing demands were documented and approved.	No exceptions noted.
INF-31	The Service Management team analyzes WAN reports on a daily basis to identify trends that may have a potential impact on the entity's ability to achieve its system availability and related security objectives.	Inspected the WAN reports for a selection of days and determined that trends identified that impact DLLP's ability to achieve the system availability and security objectives were monitored and resolved.	No exceptions noted.

Availability 1.2

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-21	A BIA is performed each fiscal year to identify threats and document the likelihood and impact of identified threats to software, hardware, people, and physical assets.	Inspected the BIA and determined that a BIA was performed annually to identify threats to software, hardware, people, and physical assets.	No exceptions noted.
INF-22	A DR plan, including dependencies, maximum allowable downtime, and response plans, is approved annually, implemented, and maintained.	Inspected the DR plan and determined that the plan contained dependencies, maximum allowable downtime, and response plans, and was approved and updated annually.	No exceptions noted.
INF-26	A site-level threat assessment is conducted each fiscal year of the actual threat environment to identify environmental or physical threat changes.	Inspected the most recent threat assessment for the Hermitage Data Center, USI communication rooms, and USM communication room and determined that the threat assessment included physical and environmental threats and was updated during the last fiscal year and approved by management.	No exceptions noted.
INF-59	Critical infrastructure components (e.g., network availability, servers, network devices) are monitored for availability on an ongoing basis through automated alerting and corrective action is implemented in a timely manner when necessary.	Inspected the availability monitoring agent documentation for a selection of servers and network devices and determined that the monitoring agent was present. Inspected the details and configuration for a selection of monitoring alert rules and determined that alert rules were in place and configured to monitor critical infrastructure components (e.g., network availability, servers, network devices) for availability. Inspected the corresponding ticket for a selection of availability alerts and determined that corrective action was implemented in a timely manner.	No exceptions noted.

Availability 1.2

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-61	Incremental backups are scheduled to run on a daily basis and complete successfully. Backup jobs that do not initially complete successfully are restarted or escalated until resolved.	Inspected the backup schedule for a selection of servers and determined that backups were scheduled to run on a daily basis. Inspected the backup logs for a selection of servers and days and determined that jobs were ran on a daily basis according to the defined schedule and completed successfully. Inspected the incident ticket for a selection of backup job failures and determined that backup failures were tracked and escalated until resolved.	No exceptions noted.
INF-82	Backups are replicated successfully to an offsite location.	Inspected the backup replication schedule and determined that backups were configured to replicate successfully to an offsite location. Inspected the backup replication log for a selection of days and determined that backups were replicated successfully to an offsite location.	No exceptions noted.
INF-65	Business continuity test plans for DLLP Managed IT services are scoped and the problems identified are documented with an associated remediation action. The critical BCP or DR plans are tested on an annual basis.	Inspected a selection of business continuity and DR test plans and determined that DLLP Managed IT services were scoped, the problems identified were documented with an associated remediation action, and testing was performed on an annual basis.	No exceptions noted.

Availability 1.2

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-62	Environmental protections have been installed at the Hermitage Data Center, USI communication rooms, and USM communication room, including: • Climate control system • Thermostat sensor • Raised floor • Smoke detector • Fluid or water sensor • Fire suppression system • Uninterruptible Power Supply (UPS) • Battery • Generator	Observed the environmental protections in place at the Hermitage Data Center, USI communication rooms, and USM communication room and noted that a climate control system, thermostat sensor, raised floor, smoke detector, fluid or water sensor, fire suppression system, UPS, battery, and generator were present.	No exceptions noted.
INF-63	Environmental protection equipment is monitored for potential issues.	Inspected the automated monitoring device dashboard and alert configurations for the Hermitage Data Center and USM communication room and determined that email alerts were configured to notify operations professionals of issues. Inspected an email alert for the Hermitage Data Center and USM communication room for a selection of days and determined that operations professionals were notified of potential issues. Inspected the monitoring log for the USI communication rooms for a selection of days and determined that the environmental protection equipment was monitored for potential issues.	No exceptions noted.

Availability 1.2

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
INF-64	Environmental protections, including generators, fire suppression systems, and UPS systems, receive maintenance on at least an annual basis.	Inspected the most recent maintenance report for the generator, fire suppression system, and UPS system at the Hermitage Data Center, USI communication rooms, and USM communication room and determined that maintenance was conducted within the past year.	No exceptions noted.

Availability 1.3

The entity tests recovery plan procedures supporting system recovery to meet its objectives.

#	Control Description	Test Procedures Performed by KPMG LLP	Results of Test
Infrastructure			
INF-65	Business continuity test plans for DLLP Managed IT services are scoped and the problems identified are documented with an associated remediation action. The critical BCP or DR plans are tested on an annual basis.	Inspected a selection of business continuity and DR test plans and determined that DLLP Managed IT services were scoped, the problems identified were documented with an associated remediation action, and testing was performed on an annual basis.	No exceptions noted.
INF-22	A DR plan, including dependencies, maximum allowable downtime, and response plans, is approved annually, implemented, and maintained.	Inspected the DR plan and determined that the plan contained dependencies, maximum allowable downtime, and response plans, and was approved and updated annually.	No exceptions noted.

VI. OTHER INFORMATION PROVIDED BY MANAGEMENT OF
DELOITTE LLP

MANAGEMENT RESPONSES

#	Control Description	Results of Test	Management's Response
INF-53	Server patches are tested and approved prior to implementation to a production server and are applied within three months of issue by the vendor.	Patches were not applied within three months of issue by vendor for 2 of 3 months selected for 1 of 19 selected servers.	For the identified server in which the patches were not implemented, management noted that the agents were not reporting correctly, and patches were not applied timely. Management remediated the server in May 2025. Recently, management has transferred the patch service back to DLLP from DTL and improved processes to help ensure that agents are reporting correctly and that patches are applied in a timely manner.
INF-94	Privileged access to servers is provisioned to elevated Active Directory accounts which are managed by Secret Server.	Privileged access for 18 of 395 users was not managed by Secret Server for 7 of 20 servers selected.	Management will be working with the server owners to remediate the accounts misconfigured to help ensure that the Secret Server process is followed. Remediation is estimated to be completed by 11/26/25.